Tech Science Press

ARTICLE

A Lightweight Four-Credential Authentication and Key Agreement Protocol for AI-Enabled Edge-IIoT: Transcript-Bound Resistance to Replay and Impersonation

Xun Zhang[1], Zhiying Mu[1,*], Wu Wei[1], Zhihui Mu[1], Dejun Mu[1] and Xin Liu[2]

[1]School of Cyberspace Security, Northwestern Polytechnical University, Xi'an 710072, China
[2]School of Artificial Intelligence, Lanzhou University, Lanzhou 730000, China
*Corresponding Author: Zhiying Mu. Email: muzhiying@mail.nwpu.edu.cn

Version October 6, 2026 submitted to Comput Mater Contin

ABSTRACT: Edge intelligence places model inference and data aggregation on edge nodes deployed outside tightly controlled premises. The edge node therefore decides who may query a deployed model and whose measurements may reach its input. We present an authentication and key agreement scheme using a password, smart card, biometric, and Cognitively Evaluable Authentication Factor (CEAF). CEAF is a session-dependent knowledge credential derived from a fresh challenge and checked against edge-side state. The hash–XOR exchange uses nonces and timestamps, while version-bound two-record state tolerates one lost authentication message without re-registration. The ROR analysis separates password and biometric guessing, transcript collisions, forgery, and CEAF-response enumeration. Sensitivity analysis shows how the residual guessing probability changes with the segment count and the admitted-attempt budget. The main protocol provides session-key independence but neither perfect forward secrecy nor key opacity from the edge node. The analytical unit-cost estimate is 0.4588 ms; a host reference implementation measured 0.0226 ms for the summed software roles on an AMD Ryzen 7 7800X3D, excluding communication and I/O. The construction is a pre-inference access-control mechanism for edge-intelligent IIoT, not a model-level defense. In particular, because Q_1 is a transcript-bound hash, exposure of the smart card, password, and biometric permits offline enumeration of the CEAF response from a recorded login; the scheme does not claim offline resistance under that compromise.

KEYWORDS: security guardrails for AI systems; AI-enabled Industrial Internet of Things; edge intelligence; pre-inference access control; authentication and key agreement; automated credential attacks

1 Introduction

The convergence of the Internet of Things and cyber-physical systems has made IIoT networks responsible for increasingly time-sensitive monitoring and control. Sending all sensor data to a remote cloud introduces transmission adds delay, bandwidth contention, and unnecessary exposure of operational data [1,58–61][1]. Edge computing addresses this problem by moving moves computation and storage closer to the data source [2,3]. In current deployments the relocated computation increasingly carries learned models : It also hosts learned models for anomaly detection, predictive maintenance, and visual quality inspectionnow run as inference at the edge rather than in the cloud, precisely because the latency and bandwidth arguments that justified edge computing apply with greater force to model servinginspection. The "user–edge node–sensor node" architecture therefore describes an edge-intelligent system. Its : the edge node authenticates users, aggregates local data, and relays trafficbetween users and sensors, and the same node is where model

© 2026 by the Authors. Submitted to Comput Mater Contin for under a Creative Commons Attribution 4.0 International License, which permitted unrestricted use, distribution, and reproduction in any medium, provided the original work is properly cited.

queriesare answered and where the measurements feeding those models arrivesensor data, relays traffic, and serves local model queries.

This architectural change also moves the trust boundary toward devices deployed outside tightly controlled premises. Edge nodes and sensor nodes may be resource constrained resource-constrained or physically accessible , while both communication links are devices connected by public wireless channels [4,5,62,63][4,5]. Once the edge node hosts inference, the consequence of a failed access decision widens. An unauthenticated request is no longer merely an unauthorised read; it is an unauthorised query against a deployed model, and it is the position from which model behaviour can be probed. An unauthenticated sensor is correspondingly a channel through which fabricated observations reach that model 's inputcan expose model queries or admit fabricated model inputs. Authentication is therefore the outermost guardrail of an edge-intelligent deployment, and it has to hold before any and must precede model-level defence, input filter, or output constraint becomes meaningfuldefenses. An AKA protocol for this environment must authenticate all three parties, establish a user–sensor session key, preserve endpoint anonymity on the channel, and resist replay, modification, impersonation, and man-in-the-middle attacks [6–10]. These goals must be met without expensive device-side cryptography or an auxiliary user device. We therefore [6–8]; related lightweight constructions make the same requirements explicit [9,10]. We treat the TEE-protected edge node as a trusted intermediary and state the consequences of that this assumption explicitly in Sections 3.4 and 7.

The first factor in many AKA protocols is a static password. Such passwords are exposed Static passwords remain vulnerable to low-entropy selectionchoice, reuse, leakage, keylogging, and observation , and their compromise remains relevant even when a card or biometric is added [11–14]. What has changed is not that exposure but the cost of exploiting it. Learned models of human password distributions raise the hit rate of each offline guess against a leaked verifier: neural and transformer-based guessers improve on rule- and grammar-based cracking under equal guess budgets, and generative models produce candidate lists that track real password distributions rather than dictionary heuristics [15,16]. Generative synthesis of face and voice samples turns a published photograph or a recorded utterance into a presentation attack on a biometric template [17]. Automated [11–13]; related analyses report the same exposure in deployed authentication systems [14]. Learned password models and generative biometric synthesis increase the rate of offline guesses and presentation attacks [15–17]; phishing and credential stuffing make extend the same exposure to large-scale attemptsroutine rather than artisanal. These developments share a structure worth naming: each of them accelerates the portion of the attack that runs offline, . Work performed on the attacker's own hardware , where no rate limitunder the defender's control applies. A protocol whose security rests on the secrecy of static credentials inherits that acceleration directlyis outside a defender-controlled rate limit, so protocols that rely on static credentials inherit this exposure.

A dynamic credential can reduce replay and single-observation exposure by making the accepted response session dependent [18]. Its integration into edge IIoT nevertheless creates a three-way design problem: the scheme should provide a dynamic factor, multi-factor verification , and lightweight three-party operation at the same time. To that we add a fourth requirement suggested by the preceding paragraph, namely that the credential of last resort be one whose verification cannot be carried out offline at all, so that an adversary who has automated everything else still faces a rate-controlled online verifierConventional dynamic-password or OTP designs typically require a token or repeated secret entry; local-verifier variants place additional verification material on the login device. CEAF keeps its verifier at EN and asks the user to select one candidate per segment from a fresh challenge. Unlike a fixed indexed PIN, randomized candidate positions do not expose a permanent index-to-response mapping; unlike a token-based OTP, CEAF needs no additional hardware; unlike a full manual dynamic password, it reduces the calculation to one selection per segment. At $s = 3$ this is three selections rather than 21 manual shifts, but randomized display, lighting, training, and observation affect human error and shoulder-surfing risk; no empirical error rate is claimed. The response must still be bound to the current transcript, and live requests remain subject to source/global controls. A recorded Q_1 remains an offline test when the other credentials are exposed.

Existing constructions usually satisfy only part of this objective. Hash-based WSN schemes with changing passwords have low cost but do not directly model an edge intermediary. ECC-based multi-factor schemes strengthen authentication but require point multiplication, while recent edge-specific protocols often retain a static password or support only two parties [19–27,64]. [19–21]. Other multi-factor and edge-oriented constructions make related trade-offs [22–24]; lightweight hash–XOR and batching designs provide further baselines [25–27]. The design gap is therefore not merely another factor category, but a credential whose response can be produced by the user, verified remotely, and bound to the current protocol transcript. Stated in the terms of the previous paragraph, the gap is a credential that an automated adversary cannot attack faster by spending more of its own computationa user-generated response that is dynamic, transcript-bound, and inexpensive for constrained devices. The present construction addresses that gap while treating offline CEAF enumeration after multi-credential compromise as an explicit limitation.

We introduce a Cognitively Evaluable Authentication Factor (CEAF) and build a four-credential AKA scheme around it. A fresh challenge and a memorized, evolving secret determine each response. The login device only displays candidates and collects the user's choice; the edge node verifies the response through the first-message authenticator . binds that response to the transcript. Here, a *credential* means one provisioned secret or evidence item that can be compromised and accounted for separately. Password and CEAF are both knowledge credentials, so while the smart card represents possession and the biometric represents inherence; therefore "four-credential" does not assert four statistically independent factor categories.

One point of scope deserves stating at the outset. The construction below is deliberately a The term describes the four independently provisioned inputs used by the protocol, not a claim that the scheme supplies four classical factor classes.

The construction is deliberately non-learningone: no classifier , model, or learned component appears anywhere in the protocol, and none is needed to deploy it. Its relation to intelligent systems runs in the other direction. . It supplies the access-control substrate on which layer for an edge-intelligent deployment sits, and it is designed against an adversary whose offline capability is assumed to be automated. It should accordingly be read as a guardrail rather than and is evaluated as a protocol mechanism, not as a detector, and it is evaluated as such.

Being explicit about that division avoids overclaiming in both directions. What the guardrail governs is The mechanism controls admission: which principals may open a sessionwith the edge node, which sensor may inject measurementsinto the aggregation path that feeds local inference, and whether an automated adversary who has already broken the conventional credentials can convert that break into an accepted session. What it does not govern is the behaviour of the model behind the guardrail, and which requests reach local inference. It does not control the model after an authenticated request is admitted. Prompt injectionagainst a language-model component, training-data or model poisoning, adversarial examples, and model extraction or membership inference by a legitimately authenticated client, and detection of AI-assisted ransomware are outside the construction and are the province of the model-level defences reviewed protocol and are discussed in Section 2.3. The two layers are sequential rather than substitutable: a filter on model inputs cannot help if an unauthenticated party can reach the input in the first place, and authentication cannot help against a caller who is authorised and still malicious. Section 3.3 states this division as a coverage table so that the claims of the following sections are read against itrecords this boundary. The contributions are:

1. A segmented cognitive primitive: a response guess succeeds with probability 26^{-s}, and two consecutive observations recover its state.
2. Edge-side CEAF verification, so state and transcript binding, together with source/global ingress limits for live attempts. A recorded Q_1 remains an offline test after exposure of the card, password, and biometricreduces security to rate-controlled online CEAF guessing rather than local verification. The offline acceleration available to an automated adversary therefore does not apply to the fourth credential. ; this limitation is included in the security analysis.

3. Two-record state that tolerates one lost message in the four-message authentication exchange, so that a dropped message costs one round of availability instead of forcing re-registration.
4. Correspondence analysis, an An ROR bound that separates the offline credential term from the online CEAF term, negative results, and a forward-secret design sketchcredential guessing, transcript collisions, forgery, and CEAF-response enumeration, and records the protocol's negative security results.

2 Related Work

Related AKA schemes fall into two architectural stages. Earlier WSN work places a gateway between the user and sensor. Recent edge-IIoT work replaces it with an edge node whose deployment, resources, and trust assumptions differ. The WSN literature still supplies many relevant lightweight authentication ideas.

2.1 Authentication Schemes in the WSN Stage

Wong et al. [28] introduced dynamic user authentication for resource-constrained WSNs. Das [29] identified replay, stolen-verifier, and identical-login-identity weaknesses in early designsand proposed a two-factor alternative; Paliwal [30] further studied authentication and key exchange studied authentication for industrial sensing. Turkanović and Hölbl [21] developed a dynamic-password construction that was later extended to heterogeneous IoT deployments [31]. Multi-gateway, anonymity-preserving, temporal-credential, and biometric schemes then broadened the design space [22,23,32,64–66][22,23,32]. This line of work is important for lightweight protocol design, but most schemes assume a conventional gateway and many retain a static or low-entropy first factor.

2.2 Authentication Schemes in the Edge IIoT Stage

Purpose-built edge-IIoT schemes reflect different trade-offs. Cui et al. [26] amortize authentication through batching, but bilinear pairings remain expensive for constrained devices and their semi-trusted edge model differs from ours. Shang et al. [27] use a lightweight hash–XOR construction for edge control systems, but consider two-party authentication without a smart-card-based user factor. Xu et al. [25] combine a password, smart card, and fuzzy biometric extraction with ECC; the design provides broad security coverage at the cost of several point multiplications and still retains a static password. TEE-assisted and privacy-preserving alternatives are also represented by the DAC–Intel SGX construction of Liu et al. [33] and the lightweight three-factor LAPTAS scheme of Far et al. [34]; their problem settings and mechanisms differ from the CEAF transcript binding and version-bound recovery objectives studied here. These schemes motivate a construction that combines a dynamic factor, multi-factor three-party authentication, and hash-dominated device cost. They are not all included in the numerical tables because a meaningful comparison also requires Recent edge-AI security work examines the security applications of edge intelligence [35], privacy-preserving federated learning with an edge server [36], and resource-efficient authentication for digital-twin edge networks [37]. These studies protect AI services, distributed training, or adjacent edge-network deployments; they do not evaluate the CEAF transcript binding and two-record recovery combination proposed here. The numerical tables accordingly retain only schemes with compatible parties and session-key functionality.

The broader edge-systems literature also covers security-aware task offloading in vehicular edge computing [38] and live migration of correlated virtual machines in cloud data centers [39]. Related data and service-security studies include imbalanced streaming-data clustering [40], ADS-B Tree-Chain authentication [41], and Byzantine-robust privacy-preserving cloud–edge federated learning [42]. These

works are cited to acknowledge the wider special-issue context. Their primary objectives and evaluation metrics concern offloading, migration, clustering, aviation-message integrity, or federated-model robustness, respectively, so they are not treated as direct credential-level AKA baselines for the present protocol.

2.3 Security of AI Deployments at the Network Edge

A third body of work concerns the security of the deployed model itself, and it is the literature against which the present scheme has to be positioned. Edge intelligence surveys describe the migration of training and inference toward the network edge and the resulting exposure of model security at the edge. Edge-intelligence surveys describe exposed model-serving interfaces on devices that are neither physically nor administratively protected [43,44]. Once such an interface is reachable, the query channel is itself an attack surface: prediction APIs leak enough to reconstruct a model [45] or to infer membership in its training set [46], and the broader taxonomies of adversarial machine learning organise [43,44]; prediction APIs enable model extraction and membership inference [45,46], while adversarial-learning taxonomies cover evasion, poisoning, and privacy attacks across the AI life cycle [47–49]. Recent work extends the same picture to generative components, where instructions embedded in retrieved content subvert an application built around a language model [50], and to the supply side, where poisoning of large training corpora is shown to be practically achievable [51]threats [47–49]. Indirect prompt injection and training-data poisoning are discussed in more recent analyses [50,51].

Two observations follow for the present paper. First, these attacks are defined with respect to a caller who already reaches the model; they characterise what a query can do, not who is entitled to issue itThese attacks assume that a caller can already reach the model. Access control therefore does not compete with them but conditions them, since restricting the set of principals that can reach the interface bounds how many parties are in a position to mount a query-based attack at all, while providing no protection whatsoever against an authenticated party that mounts one. Second, the same class of techniques is available to the attacker on the credential sidelimits who can issue queries but does not protect an authenticated caller. Credential attacks are also increasingly automated: model-assisted password guessing [15,16] and generative biometric synthesis [17] are what make the conventional weaken the first three credentialsa weaker foundation than they were when the underlying AKA designs were proposed. The guardrail examined here is the layer between those two developments, and the coverage table of . The present mechanism addresses the admission layer, as specified in Section 3.3fixes its boundaries.

3 Preliminaries

Hash-length convention. Throughout the protocol specification, $h(m)$ denotes the leftmost 160 bits of SHA-256(m), written $H_{160}(m) = \mathrm{Trunc}_{160}(\mathrm{SHA256}(m))$. The 160-bit profile is used for serialized protocol fields, communication accounting, and static-state accounting. The host benchmark measures the underlying full SHA-256 compression operation; truncation is applied only when a digest is used as a protocol field and therefore does not change the counted hash call. A deployment using full 256-bit fields would require a separate communication and storage calculation.

3.1 Cognitive Binding Primitive

The CEAF lets a user mentally derive a session response from a fresh challenge without storing the CEAF state on the smart card. Its role is cognitive participation and remote factor verification, not encryption. Protocol-message integrity and key establishment remain the responsibility of hashes, nonces, and timestamps. The following construction makes the response space and observation limits explicit rather than treating the cognitive factor as an unspecified human secret.

3.1.1 Challenge derivation

Let Σ be the 52 case-sensitive Latin letters and L the challenge length. Rather than interpret random bytes as letters, the login device samples a 160-bit seed σ and computes

$$RS = \mathrm{Exp}(\sigma) = \big(RS[1], \ldots, RS[L]\big) \in \Sigma^L, \quad \text{(P1)}$$

Exp reads the 20-byte outputs $h(\sigma \,\|\, 1) \,\|\, h(\sigma \,\|\, 2) \,\|\, \cdots$, accepts bytes below $208 = 4 \cdot 52$, and reduces them modulo 52. Under the random-oracle/PRF model, symbols are unbiased and the $L = 21$ output is statistically close to uniform over Σ^L. Two 160-bit hash blocks suffice except with probability 7.96×10^{-6}, giving about 2.000008 hashes in expectation. Only the masked 160-bit seed is transmitted. The expected challenge-expansion calls are included in the LD and EN hash counts reported in Table 4; they are not an additional cost term.

3.1.2 Segmented offset primitive

Fix a segment count $s \geq 1$ and a segment length ℓ with $L = s\ell$, and write $RS = RS^{(1)} \,\|\, \cdots \,\|\, RS^{(s)}$ for the partition of the challenge into s consecutive blocks of ℓ characters. The user-memorized secret is an offset vector $\mathbf{N} = (N^{(1)}, \ldots, N^{(s)}) \in \mathbb{Z}_{26}^s$ together with a step vector $\mathbf{N}_S \in \mathbb{Z}_{26}^s$. The primitive is

$$\mathrm{CT}_{\mathbf{N}}(RS) = \mathrm{CT}_{N^{(1)}}\big(RS^{(1)}\big) \,\|\, \cdots \,\|\, \mathrm{CT}_{N^{(s)}}\big(RS^{(s)}\big), \quad \text{(P2)}$$

where CT_n shifts letters by n positions modulo 26 while preserving case [52]. The workflow is:

1. At registration, U chooses $(\mathbf{N}, \mathbf{N}_S)$ and sends them to EN over the secure channel; no copy is stored on SC (Section 4.2).
2. At login, LD displays for each segment the 26 shifted candidates. U selects one per segment, producing DPW.
3. After confirmation, U and EN set $\mathbf{N} \leftarrow \mathbf{N} + \mathbf{N}_S \bmod 26$; $\mathbf{N}_S$ changes only during credential update.

We use $s = 3$, $\ell = 7$, and $L = 21$ as a reference configuration, yielding $26^3 = 17576$ responses. The user makes one candidate selection per segment rather than manually computing 21 modular shifts. In deployment, candidate positions should be randomized independently for each segment, rendered as high-contrast alphabetic glyphs, and cleared after a short bounded timeout; error feedback should not reveal the correct candidate. A fixed indexed layout would reduce the response to a static short code. The $s = 3$ reference configuration limits the interaction to three selections; $s = 4$ is a possible higher-risk setting, whereas $s \geq 5$ should be reserved for workflows with training and sufficient viewing time. Increasing s raises the response space but also increases user selections, so the parameter choice requires usability testing in the target industrial workflow. No empirical human-error rate is claimed here.

Segmenting the challenge serves two purposes. It expands the per-session response space from 26 to 26^s while keeping each user decision limited to one alphabetic column, and it permits the state to evolve independently in each segment. The login device can generate and display all candidates from the public challenge, but it cannot determine which candidate is correct because neither $\mathbf{N}$ nor $\mathbf{N}_S$ is stored locally. The edge node retains those vectors in masked form and evaluates the response only when reconstructing Q_1.

3.1.3 Security of the primitive

Guessing. A response guess succeeds with probability $26^{-s} = 2^{-14.10}$ at $s = 3$. After $\rho = 5$ failures, EN starts a fixed cooldown of deployment-defined duration; traffic cannot extend it or permanently lock the record, and Rejected M_1 messages do not update the target user's credential record, increment a per-user counter, or start a user-specific cooldown before Q_1 verifies; therefore, a plaintext PID_i cannot by itself lock the user out. A deployment may place a stateless challenge cookie or other anti-spoofing admission token before allocating per-source

state, then apply source/global rate limits also apply. This mechanism bounds ingress token buckets, replay filtering, and concurrency limits that do not use PID_i as a lock key. These are standard layered DDoS controls [53]: they bound processing and live attempts per observation interval but does do not impose a lifetime bound or prevent distributed flooding.

Observation. One observed response exposes only that session's N; two consecutive successful observations reveal $\mathbf{N}_S = \mathbf{N}_{t+1} - \mathbf{N}_t$ and all later responses. Thus the CEAF state is not recovered from one observation alone. The one-observation limit is an environmental assumption about the attacker obtaining a usable challenge–response pair (for example, through line of sight or recording), not a cryptographically enforced property. Combining one observation with the card, password, and biometric compromises all four credentials and may enable one adjacent-state attempt through the recovery window; that full-compromise case is not claimed secure.

Enumeration. With the card, password, and biometric, an adversary can test all 26^s offsets against Q_1. This case is outside the two-factor-compromise modelgeneral two-corruption experiment, but shows that the CEAF contributes only 14.10 bits at $s = 3$. It Hashing and live rate limits do not change this offline bound; removing it would require a larger or differently designed response space, or an additional uncompromised server-held secret. CEAF binds a human response to a session; it does not provide confidentiality.

3.2 Network Model

Figure 1 shows one edge domain containing multiple users and sensor nodes. A user initiates an authenticated request, a sensor supplies the requested process or environmental data, and the edge node is the sole routing and authentication intermediary. In an edge-intelligent deployment the same node also runs local analytics or model inference over the aggregated measurements, so the decision taken here fixes both who may issue a request and whose data enters the local processing pipeline; the protocol below is agnostic to what that pipeline computes. U and SN register with EN over a protected channel at deployment time; later AKA sessions use the two public wireless links without administrator involvement. Direct U–SN communication is not assumed.

Trust and resources. A TEE protects EN's protocol logic and long-term secrets. This assumption matches an edge gateway deployed as an operator-controlled trust anchor, where the TEE is intended to isolate protocol state from the host OS while the gateway must still authorize traffic and route sensor data. Physical access to the edge hardware is allowed, but extraction of TEE-protected values is outside the main model. Breaking this boundary exposes every stored CEAF state; a deployment that cannot provide this isolation is outside the stated security claim. Moreover, because the main protocol lets EN recover X and Y, the edge node also knows the session key; Section 7 records this trusted-intermediary limitation relative to semi-trusted designs [26]. A semi-trusted intermediary would be expected to relay or verify messages without learning the endpoint key, which would require a different key-establishment design and is not the trust goal adopted here. SN has the tightest computation and storage budget and therefore uses only hashes and XOR. U and EN are assumed to have renewable power and sufficient resources for biometric reproduction, challenge expansion, and state management.

3.3 The Edge Node as a Pre-Inference Control Point

Figure 1 is usually read as a routing diagram. Under edge intelligence it is better read as a control diagram, because two distinct paths converge on EN and both of them terminate at the local model rather than at a data store.

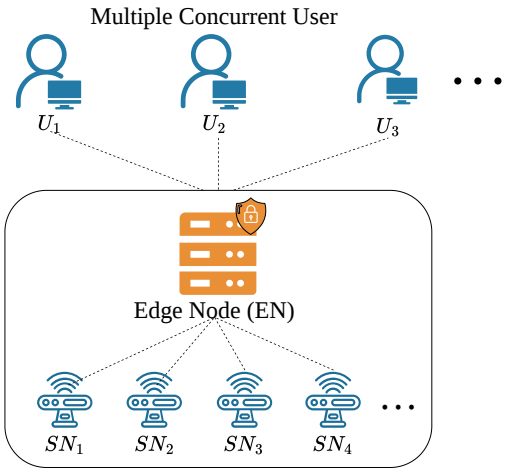


Figure 1: Network model of the edge-collaborative IIoT scheme.

On the request path, U authenticates to EN and, only after Q_1 verifies the four credentialsthe four-credential transcript check succeeds, obtains a session in which it may issue a query against the sensing service and, in a deployment that hosts analytics, against the inference service exposed by the same node. An unauthenticated unauthorized request at this position is not merely an unauthorised unauthorized read: it is an unauthorised unauthorized query against a deployed model, and repeated queries from that position are the standard precondition for extraction and membership-inference attacks [45,46]. On the ingestion path, SN authenticates to EN under TC_j before its measurements are accepted into the aggregation that feeds local processing. An unauthenticated unauthorized sensor at this position is a channel through which fabricated observations reach the model's input, which is the deployment-time analogue of data poisoning [49,51]. The protocol is agnostic to what the local pipeline computes; what it fixes is the pair of admission decisions in front of it.

The assets guarded are therefore the model-query interface, the local inference service, and the sensor-input path, together with the session key that protects the resulting user–sensor exchange. Table 1 states which attacks against those assets this paper claims to address and which it deliberately leaves to the model-level layer, so that the security claims of Sections 5 and 6 are read against a fixed boundary.

3.4 Threat Model

We use the Dolev–Yao model [12,33,54]. The adversary A may:

- control both public channels by eavesdropping, replaying, modifying, dropping, and injecting protocol messages, and also act as a registered malicious user;
- compromise at most two of the password, smart card, biometric, and CEAF credentials in the general model; we additionally analyze simultaneous exposure of the password, smart card, and biometric, in which case security reduces to rate-controlled online CEAF guessinga recorded Q_1 permits offline CEAF enumeration and live attempts remain rate controlled. The latter is a deliberately separate stress test: it diagnoses the residual CEAF entropy after three-credential exposure and does not replace the general two-corruption ROR experiment;
- capture a sensor and read all of its storage; security then concerns lateral compromise of uncaptured nodes, while the captured node itself requires revocation or re-registration;
- access edge hardware but not extract TEE-protected secrets; and
- observe the displayed challenge and selected CEAF response for at most one successful login. This observation does not by itself expose the password, card state, or biometric; combining it with

Table 1: Coverage of the authentication guardrail at an AI-enabled edge node.

Attack or exposure	Addressed here	Where
Unauthenticated access to the model-query or inference interface	Y	Sec. 4.4, Q_1
Unauthenticated or spoofed sensor input entering the aggregation path	Y	Secs. 4.2, 4.4
Offline attack on using a leaked verifier , including model-assisted guessing or recorded transcript	Y Partly	Secs. 3.1.3, 5.1.1
Exposure of up to three of the four credentials	YPartly[a]	SecsSec. 5.1.1, 5.2
Replay, modification, impersonation, man-in-the-middle	Y	Sec. 5.25
Endpoint identity exposure to a channel observer	Y[b]	Sec. 5.25
Loss of one authentication message (credential desynchronisationdesynchronization)	Y[c]	Sec. 4.4.1
Distributed flooding of the edge node	Partly[d]	Sec. 5.25
Prompt injection against a generative component	N	Sec. 2.3
Training-data or model poisoning after admission	N	Sec. 2.3
Adversarial examples at inference time	N	Sec. 2.3
Extraction or membership inference by an authenticated client	N[e]	Sec. 2.3
Detection of AI-assisted malware, ransomware, or intrusion	N	detector layeroutside scope
Extraction of TEE-protected edge secrets	N	Sec. 3.2

[a] With (SC, PW, BIO) exposed, a recorded Q_1 permits offline enumeration of the CEAF response; live attempts remain subject to deployment source/global limits, but no offline resistance is claimed. [b] Anonymity from the channel, not from EN. [c] The two-record window absorbs one lost M_1–M_4 message; repeated sensor-side loss invokes authenticated M_{R1}–M_{R2} recovery, while credential update uses a separate bounded authenticated retry. [d] Source/global ingress and concurrency limits reduce processing pressure but do not prevent distributed flooding. [e] The guardrail bounds *who* may query, which reduces the population able to mount such attacks, but gives no protection once a client is authenticated.

all three is full credential compromise and is outside the security claim. Two consecutive CEAF observations recover $(\mathbf{N}, \mathbf{N}_S)$ and are likewise excluded; this is an environmental observation bound, not a cryptographic guarantee; and

- automate any of the above, including with learned or generative components. Automation is treated as a change in password guessing or biometric synthesis. Automation changes the rate and per-attempt success probabilityof guessing and of biometric synthesis, not as a change in , not the set of values obtainable by A. In particular, offline Offline work against a password verifier or a biometric template is assumed to be as fast as proceed at the adversary's own hardware allows, and is bounded only through the credential terms of Section 5.1; the hardware speed. The one-successful-login limit on CEAF observation is retained as a modelling a modeling assumption and is revisited in Section 7.

The adversary is correspondingly *not* assumed to attack the model behind the guardrail. Adversarial examples, poisoning of the locally hosted model, prompt injection against a generative component, and extraction or membership inference mounted from a session that has already been admitted are excluded by assumption rather than defended against; Table 1 records the division and Section 2.3 identifies the layer to which those attacks belong. A registered malicious user remains inside the model in the sense of the first bullet—it may deviate arbitrarily in the protocol—but protocol, but no claim is made about what it does with the inference service once a session is established.

For the main protocol, corruption Corruption of R_i, TC_i, TC_j, or R_{EN} makes a main-protocol session non-fresh because those these values reconstruct transcript nonces. The PFS design sketch instead considers post-session long-term corruption after the ephemeral scalars have been erased. Hash inversion, second-preimage construction, collision finding, nonce prediction, and compromise of the secure registration channel are assumed infeasible. All claims in Section 5 are scoped to these freshness and compromise conditions.

Table 2: Notation definitions.

Symbol	Meaning
U, EN, SN	User, edge node, sensor node
LD, SC	User device and smart card
SA, A	System administrator, adversary
$ID_i, ID_{SC}, ID_{SN}, ID_{EN}$	Unique identities of U, SC, SN, EN
PID_i, PID_j	Persistent pseudo-identities of U and SN
PID_{SN}	One-time pseudo-identity of SN
PW_i, SK	User static password and session key
TS, ΔT, σ	Timestamp, acceptance window, and 160-bit challenge seed
r_R, C_R^{cur}, C_R^{prev}	Resynchronization nonce and masked sensor-version identifiers
RS, $\mathrm{Exp}(\cdot)$	Challenge $RS = \mathrm{Exp}(\sigma) \in \Sigma^L$ and its expansion function
s, ℓ, L	Segment count, segment length, challenge length $L = s\ell$
$\mathbf{N}$, $\mathbf{N}_S$	CEAF offset vector and step vector in $\mathbb{Z}_{26}^s$
DPW	One-time CEAF response $\mathrm{CT}_{\mathbf{N}}(RS)$
ρ, ctr_i Consecutive-failure limit and its counter at EN	$\mathrm{Gen}(\cdot)/\mathrm{Rep}(\cdot)$ Generation/reproduction algorithm of the fuzzy extractor
$\mathrm{CT}_{\mathbf{N}}(\cdot)$	Segmented cognitive-binding primitive with offset vector $\mathbf{N}$
$h(\cdot)$, $\|$, $\oplus$	Hash function, concatenation, XOR
$\mathrm{enc}_s, \mathrm{dec}_s$	Fixed-length encoding of $\mathbb{Z}_{26}^s$ and its inverse on the encoding image
T_H, T_F	Analytical unit costs of one hash and one fuzzy-extractor operation; values are illustrative

3.5 Notation

The notation used throughout this paper is listed in Table 2.

4 The Proposed Scheme

The scheme has initialization, registration, login, AKA, and update phases, plus the PFS design sketch of Section . Verification is deliberately divided between two locations: LD checks the password, card, and biometric, while EN checks the CEAF through the first protocol authenticator. Consequently, possession of the first three credentials does not provide a local CEAF verifier , although it leaves a rate-controlled online guessThe transcript binding prevents a verifier from being stored on the card, but a recorded Q_1 can still be tested offline after the other three credentials are exposed. Apart from fuzzy reproduction and challenge expansion, the main protocol uses hashes, XOR, nonces, and timestamps. The rotating Rotating pseudo-identities and CEAF state are maintained as version-bound two-record windows to tolerate one lost authentication message. Protocol displays are numbered $(P1), (P2), \ldots$ for implementation reference; the analytical security bounds use ordinary equation numbers (1)–(3).

4.1 System Initialization Phase

Before deployment, the system administrator SA provisions each device as follows:

1. Install the primitive set $\{\oplus, h(\cdot), \|\}$ on every LD, EN, and SN.
2. Install the challenge-expansion function $\mathrm{Exp}(\cdot)$ of from Section 3.1.1 on every LD and EN, the segmented cognitive-binding primitive ; install $\mathrm{CT}_{\mathbf{N}}(\cdot)$ on every EN and on every in the LD display routine, and the fuzzy-extractor algorithms install $\{\mathrm{Gen}(\cdot), \mathrm{Rep}(\cdot)\}$ on every LD.

3. Fix the CEAF parameters (s, ℓ, ρ) (s, ℓ) and timestamp-acceptance window ΔT system-wide; this paper uses $(3, 7, 5)$ for the CEAF parameters. Let $\langle\cdot\rangle$ $(3, 7)$. Let $\langle\cdot\rangle = \mathrm{enc}_s(\cdot)$ denote the fixed-length 160-bit encoding of a vector in $\mathbb{Z}_{26}^s$, and let dec_s be its inverse on the encoding image. Thus dec_s is string decoding, not group inversion. Source/global ingress budgets are deployment parameters and are not stored in Λ_i.
4. Assign a unique identity ID_{SC} to each smart card, ID_{SN} to each sensor node, and ID_{EN} to the edge node. Each edge domain samples one master secret R_{EN} and seals it inside the TEE before any registration.

4.2 Registration Phase

Registration uses a secure channel and binds each user to a unique smart card and each sensor to the edge domain. Long-term credentials are stored in masked form, and R_{EN} remains inside the TEE. The user sends the CEAF vectors to EN only during registration and erases the working copies on LD; this placement is what prevents the card or login device from becoming a CEAF verification oracle.

4.2.1 User Registration

1. U supplies its identity, password, biometric, and CEAF vectors. LD reads ID_{SC}, samples R_i, obtains TS_1, and computes

$$\begin{aligned} (R_U, P_U) &= \mathrm{Gen}(BIO_i), \\ UID_i &= h(ID_i \,\|\, PW_i), \\ HPW &= h(ID_i \,\|\, PW_i \,\|\, ID_{SC} \,\|\, R_U \,\|\, R_i), \end{aligned} \tag{P3}$$

then sends the registration tuple

$$\{UID_i, ID_{SC}, HPW, R_i, \langle \mathbf{N} \rangle, \langle \mathbf{N}_S \rangle, TS_1\} \tag{P4}$$

to EN over the secure channel and erases the CEAF vectors.
2. After checking TS_1, EN uses its TEE-resident domain secret R_{EN}, obtains TS_2, and computes

$$\begin{aligned} TC_i &= h(R_{EN} \,\|\, R_i), \\ PID_i &= h(UID_i \,\|\, ID_{SC} \,\|\, R_i), \\ PTC_i &= TC_i \oplus h(R_i \,\|\, UID_i \,\|\, HPW), \\ RPW &= h(TC_i \,\|\, R_i), \end{aligned} \tag{P5}$$

returns $\{PID_i, RPW, PTC_i, TS_2\}$ to LD. On the EN side it then forms the masked credential state

$$\begin{aligned} PK_i &= R_i \oplus h(R_{EN} \,\|\, ID_{EN}), \\ PN_{EN} &= \langle \mathbf{N} \rangle \oplus h(TC_i \,\|\, R_{EN}), \\ PNS_{EN} &= \langle \mathbf{N}_S \rangle \oplus h(TC_i \,\|\, ID_{EN} \,\|\, R_{EN}), \end{aligned} \tag{P6}$$

and stores the two-record state

$$\Lambda_i = \{PID_i^{cur}, PID_i^{prev}, PK_i, PN_{EN}, PNS_{EN}, ctr_i\}, \; \Lambda_i = \{PID_i^{cur}, PID_i^{prev}, PK_i, PN_{EN}, PNS_{EN}\}, \tag{P7}$$

with $PID_i^{cur} = PID_i^{prev} = PID_i$ and $ctr_i = 0$. Because PK_i is masked by R_{EN} rather than PID_i, only the rotating identifier is duplicated. The CEAF vectors remain only at EN; invalid authentication attempts do not modify this record.
3. After checking TS_2, LD computes

$$PR_i = R_i \oplus h(UID_i \,\|\, ID_{SC} \,\|\, R_U) \tag{P8}$$

and stores the five fields PID_i, RPW, PTC_i, PR_i, and P_U, then erases its working secrets. The provisioned public identifier ID_{SC} is not counted as cryptographic state, and SC stores no CEAF representation.

4.2.2 Sensor-Node Registration

Sensor registration proceeds as follows.

1. SN takes its own identity ID_{SN}, samples R_j, computes $PID_j = h(ID_{SN} \| R_j)$ and $TC_j = h(R_j \| ID_{SN} \| ID_{EN})$, obtains TS_1, and sends $\{ID_{SN}, R_j, TS_1\}$ to EN. It retains PID_j until the returned state is installed.
2. Upon receipt, EN first checks the freshness of TS_1; if it has expired, EN aborts. Otherwise EN obtains TS_2 and computes

$$\begin{aligned} PID_j &= h(ID_{SN} \,\|\, R_j), \\ TC_j &= h(R_j \,\|\, ID_{SN} \,\|\, ID_{EN}), \\ PK_j &= R_j \oplus h(PID_j \,\|\, ID_{EN}), \\ PTC_j &= TC_j \oplus PID_j, \end{aligned} \tag{P9}$$

returns $\{PTC_j, TS_2\}$ to SN, and stores the two-record state $\Lambda_j = \{PID_j^{cur}, PID_j^{prev}, PK_j\}$ indexed by ID_{SN}, with $PID_j^{cur} = PID_j^{prev} = PID_j$.
3. Upon receipt, SN first checks the freshness of TS_2; if it has expired, SN aborts. Otherwise SN stores $\{PTC_j^{cur}, PTC_j^{prev}\}$, both initialised to $\{PID_j^{cur}, PID_j^{prev}, PTC_j^{cur}, PTC_j^{prev}\}$, with both PID entries initialized to PID_j and both PTC entries initialized to PTC_j; it then erases R_j and TC_j.

4.3 User Login Phase

The login phase separates local screening from remote authentication. LD first rejects an incorrect password, card, or biometric without creating network traffic. It then only collects collects only the CEAF response; EN verifies that response through M_1. This order limits unnecessary edge and sensor work while preserving the requirement that the fourth credential be checked against edge-only state.

(1) Verification of the first three credentials (static password, smart card, biometric). U inserts SC into LD, inputs $\{ID_i, PW_i\}$, and imprints provides biometric BIO_i. LD reads the smart-card state and computes

$$\begin{aligned} UID_i &= h(ID_i \,\|\, PW_i), \\ R_U &= \mathrm{Rep}(P_U, BIO_i), \\ R_i &= PR_i \oplus h(UID_i \,\|\, ID_{SC} \,\|\, R_U), \\ HPW &= h(ID_i \,\|\, PW_i \,\|\, ID_{SC} \,\|\, R_U \,\|\, R_i), \\ TC_i &= PTC_i \oplus h(R_i \,\|\, UID_i \,\|\, HPW), \\ RPW^* &= h(TC_i \,\|\, R_i). \end{aligned} \tag{P10}$$

If $RPW^* \neq RPW$, LD rejects; otherwise the first three credentials pass.

(2) CEAF collection. U selects the target sensor ID_{SN} and verifies the target shown by LD. LD then samples σ, displays the candidate columns for $RS = \mathrm{Exp}(\sigma)$, and receives DPW. It retains (σ, RS, DPW) only through M_1 construction and does not verify DPW. U advances the offset only after session confirmation.

4.4 Authentication and Key Agreement Phase

U, EN, and SN authenticate, establish SK for U and SN, and rotate credentials. M_1 binds the four-credential login and target sensor, M_2 carries the edge contribution to the selected sensor, M_3 returns the sensor contribution, and M_4 confirms both nonces to the user. Trusted Because EN is trusted, it learns X, Y, and therefore SK (A15); it verifies the CEAF in step (2). The timestamps provide freshness, whereas the Q values bind the reconstructed fields and prevent an adversary from changing a timestamp or masked nonce independently.

All replay and concurrency checks are atomic. Within ΔT, EN caches (PID_i, Q_1, TS_1) for M_1, and SN caches (PID_j, Q_2, TS_2) for M_2. For M_3 and M_4, EN and LD cache (Q_3, TS_3) and (Q_4, TS_4), respectively. A duplicate is rejected before any state transition. LD retains one outstanding local context; EN and SN allow at most one accepted in-flight session for the relevant user and sensor records. M_3 must match the sole pending sensor context at EN, and M_4 must match the outstanding context at LD. Reservations and replay entries expire after ΔT. These bounded caches and locks are required protocol metadata but are excluded from the static cryptographic-storage comparison in Section 6.

(1) LD samples a fresh random number X, obtains a timestamp TS_1, and computes

$$\begin{aligned} PKS_1 &= X \oplus h(R_i \,\|\, TC_i \,\|\, TS_1), \\ PRS &= \sigma \oplus h(X \,\|\, TC_i \,\|\, TS_1), \\ PID_{SN} &= ID_{SN} \oplus h(X \,\|\, TC_i), \\ Q_1 &= h(X \,\|\, ID_{SN} \,\|\, PID_i \,\|\, RS \,\|\, DPW \,\|\, TS_1). \end{aligned} \tag{P11}$$

LD sends

$$M_1 = \{PID_i, PKS_1, PRS, PID_{SN}, Q_1, TS_1\} \tag{P12}$$

to EN and erases DPW. Q_1 binds the untransmitted response, while PRS masks the challenge seed.

(2) Upon receipt, EN checks the freshness of TS_1 and the M_1 replay key; if either check fails, EN aborts. Otherwise EN locates the first searches for a state Λ_i whose PID_i^{cur} equals the received PID_i , recording and records $v_i = cur$, and failing that the state whose PID_i^{prev} equals it , recording . If no current value matches, it searches the previous values and records $v_i = prev$; if neither . If neither value matches or the record already has an in-flight session, EN aborts. If the record is in a fixed-duration cooldown, Source/global ingress and concurrency controls are applied independently of PID_i; they may reject traffic before this step but never create a user-specific lock. EN rejects the message without evaluating Q_1 and without extending the cooldown. Otherwise EN then recovers

$$\begin{aligned} R_i &= PK_i \oplus h(R_{EN} \,\|\, ID_{EN}), \\ TC_i &= h(R_{EN} \,\|\, R_i), \\ X &= PKS_1 \oplus h(R_i \,\|\, TC_i \,\|\, TS_1), \\ \sigma &= PRS \oplus h(X \,\|\, TC_i \,\|\, TS_1), \quad RS = \mathrm{Exp}(\sigma), \\ ID_{SN} &= PID_{SN} \oplus h(X \,\|\, TC_i), \\ \mathbf{N} &= \mathrm{dec}_s\big(PN_{EN} \oplus h(TC_i \,\|\, R_{EN})\big), \\ \mathbf{N}_S &= \mathrm{dec}_s\big(PNS_{EN} \oplus h(TC_i \,\|\, ID_{EN} \,\|\, R_{EN})\big), \\ Q_1^* &= h(X \,\|\, ID_{SN} \,\|\, PID_i \,\|\, RS \,\|\, \mathrm{CT}_{\mathbf{N}}(RS) \,\|\, TS_1). \end{aligned} \tag{P13}$$

If Q_1 fails and $v_i = prev$, EN retries once with $\mathbf{N}^- = \mathbf{N} - \mathbf{N}_S \bmod 26$; it never tries $\mathbf{N}^-$ for PID_i^{cur}. A match adopts the preceding offset. Any other mismatch increments ctr_i and aborts . At ρ, a non-extending fixed cooldown begins; success resets ctr_i. After successaborts without changing Λ_i or any user-specific availability state. After a valid Q_1, EN atomically inserts the M_1 replay key and reserves the user record. Acceptance jointly verifies the four credentials. EN then retrieves Λ_j; if its sensor record is busy, EN releases the user reservation and aborts. Otherwise it reserves that record, uses PID_j^{cur}, obtains TS_2, and computes

$$\begin{aligned} R_j &= PK_j \oplus h(PID_j \,\|\, ID_{EN}), \\ TC_j &= h(R_j \,\|\, ID_{SN} \,\|\, ID_{EN}), \\ PKS_2 &= X \oplus h(TC_j \,\|\, TS_2), \\ Q_2 &= h(X \,\|\, PID_j \,\|\, TS_2), \end{aligned} \tag{P14}$$

and sends $M_2 = \{PID_j, PKS_2, Q_2, TS_2\}$ to the SN designated by ID_{SN}.

(3) After checking TS_2, the M_2 replay key, and the absence of another in-flight session, SN recovers $TC_j = PTC_j^{cur} \oplus PID_j$ first matches the received PID_j against the stored current/previous pair. If neither

identifier matches, it invokes the authenticated resynchronization of Section 4.4.2 and does not process M_2. Otherwise, with $v_j \in \{cur, prev\}$ denoting the matching version, SN recovers $TC_j = PTC_j^{v_j} \oplus PID_j$ and X, then verifies Q_2. On failure it retries once with PTC_j^{prev}; if both checks failIf the check fails, it aborts without changing state. On success it atomically inserts the replay key, reserves the record, obtains TS_3, samples Y, derives $SK = h(X \| Y)$, and computes

$$PKS_3 = Y \oplus h(TC_j \| X \| TS_3), \quad Q_3 = h(X \| Y \| TS_3), \tag{P15}$$

then sends

$$M_3 = \{PKS_3, Q_3, TS_3\} \text{ and shifts } (PTC_j^{cur}, PTC_j^{prev}) \text{ after deriving} \tag{P16}$$

and derives $PID_j^* = PID_j \oplus h(Y \| TS_3)$ and $PTC_j^* = TC_j \oplus PID_j^*$. It atomically shifts the sensor state to $(PID_j^*, PID_j, PTC_j^*, PTC_j)$, then releases its in-flight reservation while retaining the replay entry for ΔT.

(4) After checking TS_3, matching M_3 to the pending sensor context, and rejecting a cached M_3 key, EN recovers Y and verifies Q_3. It then atomically inserts the replay key, obtains TS_4, and computes

$$PKS_4 = Y \oplus h(R_i \| TC_i \| X \| TS_4), \quad Q_4 = h(X \| Y \| TS_4), \tag{P17}$$

and sends $M_4 = \{PKS_4, Q_4, TS_4\}$ to the LD held by U. EN then advances both credential states, keeping the value it has just used as the previous entry:

$$PID_j^* = PID_j \oplus h(Y \| TS_3), \quad PK_j^* = R_j \oplus h(PID_j^* \| ID_{EN}),$$
$$PID_i^* = PID_i \oplus h(X \| TS_4), \quad \mathbf{N}^* = \mathbf{N} + \mathbf{N}_S \bmod 26, \tag{P18}$$
$$PN_{EN}^* = \langle \mathbf{N}^* \rangle \oplus h(TC_i \| R_{EN}),$$

$$\{PID_j^{prev}, PID_j^{cur}, PK_j\} \leftarrow \{PID_j, PID_j^*, PK_j^*\}, \quad \{PID_i^{prev}, PID_i^{cur}, PN_{EN}\} \leftarrow \{PID_i, PID_i^*, PN_{EN}^*\}. \tag{P19}$$

Here PID_i and PID_j are the values used in this round; PK_i and PNS_{EN} remain unchanged. After the atomic commit, EN releases both in-flight reservations while retaining the replay entries until they expire.

(5) After checking TS_4, matching the sole outstanding context, and rejecting a cached M_4 key, LD recovers Y, derives SK, and verifies Q_4. It then atomically caches the key, stores $PID_i^* = PID_i \oplus h(X \| TS_4)$, consumes the outstanding context, and signals success, after which U advances $\mathbf{N}$. If M_4 is lost, U retains the old state and step (2) absorbs the next login.

4.4.1 Two-record state and the desynchronization invariant

SN commits when it sends M_3, EN when it sends M_4, and U after verifying M_4. Dropping A single lost M_3 or M_4 therefore leaves adjacent principals at most one round apartand, without recovery , causes permanent credential desynchronisationwhich the two-record window absorbs. If repeated loss moves SN beyond the identifiers retained by EN, the normal exchange stops and the authenticated recovery below is invoked; no unauthenticated rollback is allowed. The invariant protects state consistency, not availability under sustained loss: recovery still depends on delivery of the authenticated resynchronization exchange.

Each rotating value is therefore held as a version-bound $(cur, prev)$ pair:

$$EN : (PID_i^{cur}, \mathbf{N}),\ (PID_i^{prev}, \mathbf{N} - \mathbf{N}_S),\ (PID_j^{cur}, PID_j^{prev}), \quad SN : (PTC_j^{cur}, PTC_j^{prev}). \tag{P20}$$

$EN : (PID_i^{cur}, \mathbf{N}),\ (PID_i^{prev}, \mathbf{N} - \mathbf{N}_S),\ (PID_j^{cur}, PID_j^{prev}),$
$SN : (PID_j^{cur}, PID_j^{prev}, PTC_j^{cur}, PTC_j^{prev}).$

$\mathbf{N}^-$ is recomputed from $(\mathbf{N}, \mathbf{N}_S)$, avoiding another stored copy. A current PID_i is verified only with $\mathbf{N}$, whereas $\mathbf{N}^-$ is available only after a previous-PID_i match. Thus identifiers and CEAF offsets cannot be mixed across versions: a current identifier is never tested with the previous offset, and a previous identifier is never promoted to the current version without the adjacent-state commit. A previous-value match is accepted only for the immediately adjacent state and is followed by the normal commit rule. Together with the replay cache and single-session reservation, this one-round window recovers one lost M_1–M_4

without accepting a duplicate transcript. It Repeated sensor-side loss is handled only by the authenticated resynchronization below; credential update remains separate.

4.4.2 Authenticated sensor resynchronization

If SN receives an M_2 whose PID_j matches neither stored identifier, it derives $TC_j = PTC_j^{cur} \oplus PID_j^{cur}$, samples fresh (r_R, TS_R), and computes

$$\begin{aligned} C_R^{cur} &= PID_j^{cur} \oplus h(TC_j \| r_R \| 1), \\ C_R^{prev} &= PID_j^{prev} \oplus h(TC_j \| r_R \| 2), \\ Q_R^{(1)} &= h(TC_j \| C_R^{cur} \| C_R^{prev} \| r_R \| TS_R \| \mathrm{r1}), \end{aligned} \tag{P21}$$

It sends $M_{R1} = \{C_R^{cur}, C_R^{prev}, r_R, Q_R^{(1)}, TS_R\}$ and waits without changing state. EN recovers R_j from (PID_j^{cur}, PK_j), derives TC_j, checks freshness, replay, and $Q_R^{(1)}$, then cancels the stale M_2 context and releases its reservations. It recomputes $PK_j^* = R_j \oplus h(C_R^{cur} \| ID_{EN})$, installs $(PID_j^{prev}, PID_j^{cur}, PK_j) = (C_R^{prev}, C_R^{cur}, PK_j^*)$, and returns

$$Q_R^{(2)} = h(TC_j \| C_R^{cur} \| C_R^{prev} \| r_R \| TS_R \| \mathrm{r2}), \qquad M_{R2} = \{r_R, Q_R^{(2)}, TS_R\}. \tag{P22}$$

SN accepts M_{R2} only for its outstanding r_R and a valid $Q_R^{(2)}$. It then installs the four recovered fields $(C_R^{cur}, C_R^{prev}, TC_j \oplus C_R^{cur}, TC_j \oplus C_R^{prev})$ and clears the request. If the acknowledgement is lost, it retransmits the same M_{R1} within ΔT and EN returns the cached acknowledgement without another state transition. This idempotent exchange repairs repeated sensor-side loss when the two endpoints can still exchange authenticated messages; it is excluded from the normal-session cost and does not claim arbitrary rollback tolerance and excludes credential updateavailability against distributed flooding or a permanently partitioned link.

4.5 Credential Update Phase

Password and biometric updates are card-local because they only change the masks used to recover R_i and TC_i. Changing the edge-held CEAF vectors requires the protected exchange below. The update is executed only after a complete AKA run so that LD and EN can protect the new vectors with a fresh update key rather than with the user's low-entropy credentials. The replay-cache and single-pending-context rules of Section 4.4 also apply to M_5 and M_6 within ΔT. The update replay keys are (Q_5, TS_5) at EN and (Q_6, TS_6) at LD. LD keeps the pending update until a valid M_6 is received and retransmits the same M_5 after a timeout; EN caches the accepted update and its M_6 for this retry window and resends it without a second state transition. Thus, one lost M_6 is recovered by an authenticated retry rather than by re-registration.

1. LD completes Sections 4.3–4.4; U and EN set $SK_{UE} = h(TC_i \| X \| Y)$.
2. U selects any subset of a new password, biometric, CEAF vector, and CEAF step vector. An unchanged starred value equals its current value. For a password-only update, $(R_U^*, P_U^*) = (R_U, P_U)$; for a biometric-only update, $PW_i^* = PW_i$. If only one CEAF vector changes, the other starred vector equals its current value.
3. If the biometric changes, LD obtains $(R_U^*, P_U^*) = \mathrm{Gen}(BIO_i^*)$; otherwise it reuses (R_U, P_U). It then recomputes the card-local values

$$\begin{aligned} UID_i^* &= h(ID_i \| PW_i^*), \\ HPW^* &= h(ID_i \| PW_i^* \| ID_{SC} \| R_U^* \| R_i), \\ PTC_i^* &= TC_i \oplus h(R_i \| UID_i^* \| HPW^*), \\ PR_i^* &= R_i \oplus h(UID_i^* \| ID_{SC} \| R_U^*), \end{aligned} \tag{P23}$$

If neither CEAF vector changes, LD atomically commits the five card fields, using PTC_i^*, PR_i^*, and P_U^*, and erases the working values. The update then ends without contacting EN. If either CEAF vector changes, LD obtains TS_5 and computes

$$C_1 = \langle \mathbf{N}^* \rangle \oplus h(SK_{UE} \| 1 \| TS_5),$$
$$C_2 = \langle \mathbf{N}_S^* \rangle \oplus h(SK_{UE} \| 2 \| TS_5), \quad \text{(P24)}$$
$$Q_5 = h(SK_{UE} \| \langle \mathbf{N}^* \rangle \| \langle \mathbf{N}_S^* \rangle \| TS_5),$$

sending $M_5 = \{C_1, C_2, Q_5, TS_5\}$ to EN.

4. After Upon receiving M_5, EN first checks its pending-update cache. If (Q_5, TS_5) matches an accepted update still within the retry window, it retransmits the cached M_6 and makes no state change. Otherwise, after checking TS_5 and its the replay key, EN recovers

$$\langle \mathbf{N}^* \rangle = C_1 \oplus h(SK_{UE} \| 1 \| TS_5),$$
$$\langle \mathbf{N}_S^* \rangle = C_2 \oplus h(SK_{UE} \| 2 \| TS_5). \quad \text{(P25)}$$

It verifies Q_5, obtains TS_6, and computes

$$PN_{EN}^* = \langle \mathbf{N}^* \rangle \oplus h(TC_i \| R_{EN}),$$
$$PNS_{EN}^* = \langle \mathbf{N}_S^* \rangle \oplus h(TC_i \| ID_{EN} \| R_{EN}), \quad \text{(P26)}$$
$$Q_6 = h(SK_{UE} \| \langle \mathbf{N}^* \rangle \| \langle \mathbf{N}_S^* \rangle \| TS_6).$$

EN atomically stores the two starred masks, resets ctr_i, caches the accepted update and M_6, and returns $M_6 = \{Q_6, TS_6\}$. It never applies an accepted update twice, and no failed M_1 attempt can alter this update state.

5. After checking TS_6 and verifying and caching M_6 against both starred CEAF vectors, LD commits any new card values and U memorizes the new CEAF pair. Otherwise both retain their Until this check succeeds, the old local values . Because EN may already have committed, loss of are retained. If M_6 can require authenticated recovery or re-registration; A14 therefore covers only M_1–M_4. is lost, LD retransmits the unchanged M_5 within ΔT; the cached response above is returned and the update is committed only once. If all retries expire, LD reports an incomplete update and retains its old local values; loss-atomicity is not claimed outside this bounded retry window.

The main protocol lacks PFS because later long-term compromise recovers transcript nonces and past keys. It also gives EN visibility of the user–sensor key. The following design sketch shows how an authenticated ephemeral DH exchange could address both limitations while preserving the four-message structure; it is not presented as a fully specified or independently verified protocol.

Let P generate a prime-order group where CDH is hard. LD sends $A = xP$ in

4.6 Implementation-Oriented Message Summary

The main exchange can be implemented from the following compact summary; a failed verification leaves the corresponding state unchanged. M_1 and binds it into $(LD \to EN)$ binds the four credentials, challenge, target sensor, and nonce in Q_1; EN relays and binds A in M_2. After validating A, verifies CEAF and reserves the user record. M_2 $(EN \to SN)$ carries the masked edge contribution and Q_2; SN sends $B = yP$ in verifies the sensor context and derives its session contribution. M_3 , computes $K = yA$, and sets $SK = h(X \| Y \| K_x \| A \| B)$. Q_3 and Q_4 bind (A, B), while $(SN \to EN)$ returns the sensor contribution and Q_3; SN shifts its two-record state after sending, while EN verifies the pending context. M_4 relays B. $(EN \to LD)$ confirms both nonces with Q_4; LD validates B, computes $K = xB$, and derives the same key. Invalid or substituted points are rejected by validation or tag failure.

Under honest execution, validation of both points, and erasure of (x, y), CDH prevents recovery of K from later long-term compromise. Binding both public points to the authenticators is necessary: relaying an unbound point would permit substitution without breaking the hash tags. Against an honest-but-curious verifies the session and commits its local identifier, while EN that follows the relay procedure, the construction also hides SK because EN sees A and B but not xyP. A malicious intermediary is outside the trusted-edge model. The sketch adds four point multiplications and one 320-bit point to each message (Section 6) ; full message equations, point-validation costs, and a complete

authenticated-key-exchange proof remain future workcommits the adjacent records. Optional M_5 ($LD \to EN$) and M_6 ($EN \to LD$) update the CEAF vectors under SK_{UE}; the cached M_6 recovers one lost update acknowledgement without a second state transition.

5 Security Analysis

We analyze authentication and key secrecy at three complementary levels. BAN-style correspondences check which principal can be associated with each accepted message, a The Real-or-Random (ROR) reduction bounds transcript and guessing credential-guessing attacks, and the informal audit connects those results to the properties in Table 3. These arguments The claims are conditioned on the threat model and freshness rules of Section 3.4. In ; in particular, the main protocol claims neither PFS nor key opacity from EN.

5.1 Formal Security Analysis

BAN notation [67,68] audits message origin and freshness; ROR handles guessing and key secrecy. We use BAN terminology only for correspondence reasoning and do not treat belief derivation as a proof of secrecy. The separation is important because the edge and sensor share some effective authenticators, making principal attribution weaker than simple tag verification might suggest.

Let $\mathrm{Auth}_K(Z)$ denote a hash authenticator reproducible only with effective secret K. We use only message-meaning and nonce-verification:

$$\frac{P \models P \overset{K}{\leftrightarrow} Q,\ P \lhd \mathrm{Auth}_K(Z)}{P \models Q \mathrel{|\sim} Z}, \qquad \frac{P \models \#(Z),\ P \models Q \mathrel{|\sim} Z}{P \models Q \models Z}.$$

The idealized authenticators below retain every hashed field. K_{UE} denotes the effective collection of uncompromised values needed to reconstruct Q_1, including the edge-held CEAF state; it is not an additional protocol key.

$$\begin{aligned} M_1 &: \mathrm{Auth}_{K_{UE}}(X, PID_i, PID_{SN}, RS, DPW, TS_1),\\ M_2 &: \mathrm{Auth}_{TC_j}(X, PID_j, TS_2),\\ M_3 &: \mathrm{Auth}_{TC_j}(X, Y, TS_3),\\ M_4 &: \mathrm{Auth}_{(X,Y)}(X, Y, TS_4). \end{aligned}$$

With uncompromised secrets and freshness checks, accepted M_1 attributes the reconstructed four-credential login and target selection to U. Accepted M_2 shows that a party knowing TC_j supplied a fresh X, and accepted M_3 associates the fresh pair (X, Y) with the sensor-side credential. Finally, accepted M_4 shows that a live peer knows both nonces and the current transcript. Because both EN and SN know them in the main protocol, Q_4 distinguishes neither principal without the honest-relay assumption. These correspondences establish message origin only within the stated key-ownership assumptions; they do not by themselves prove password knowledge, PFS, or key secrecy.

5.1.1 Reduction in the Real-or-Random Model

Protocol instances answer Execute, Send, Reveal, Hash, CorruptSC, CorruptPW, CorruptBIO, and CorruptCEAF queries, followed by one Test on a fresh accepted instance. Execute exposes honest transcripts, Send models active delivery and modification, and Reveal returns an accepted session key. The general experiment permits at most two credential corruptions for one user and represents the protocol's ordinary partial-compromise claim. A separate residual-CEAF three-credential experiment exposes (SC, PW, BIO) together but not the CEAF state; its successful impersonations must pass the online because Q_1 is public in a recorded transcript, the experiment includes offline enumeration of the 26^s possible responses, while live impersonation attempts remain subject to the edge verifier. This stress test is intentionally separated because it measures the residual CEAF entropy after the other credentials are lost; it complements, rather than replaces, the general ROR experiment. Exposure of all four credentials, reveal of the tested key, or corruption of a nonce-recovery value makes the tested session non-fresh. With h a random oracle, $\mathrm{Adv}^{\mathrm{ror}}_{\Pi}(\mathrm{A}) = |2\Pr[\mathrm{Succ}] - 1|$.

Let q_h, q_s, q_n count hash queries, active sends, and sampled nonces, with lengths l_h, l_n. Let q_e count offline CEAF tests against recorded transcripts and q_c count live CEAF trials admitted by the deployment's source/global policy and reaching the CEAF verifier. Each offline or live CEAF test consumes at least one random-oracle query, so the disjoint total $q_{\mathrm{CEAF}} = q_e + q_c$ satisfies $q_{\mathrm{CEAF}} \le q_h$ and $q_c \le q_s$. Under Zipf

parameters (C', s') (C_z, α) [55] and biometric min-entropy l_b, the remaining-credential remaining password and biometric guessing probability satisfies

$$p_{\mathrm{cred}}(q_g) \le \min\left\{1,\ C' q_g^{s'} \sum_{r=1}^{q_g} r^{-\alpha} + \frac{q_g}{2^{l_b}}\right\} \tag{1}$$

where q_g counts offline guesses. Let password and biometric guesses, and $C_z r^{-\alpha}$ is the Zipf probability assigned to rank r. The deployment's source/global admission policy bounds q_c count online CEAF trials passing identifier and freshness filters; rate controls bound q_c per observation interval, not for the ; this bound is not a per-user lock and is not assumed to hold for the entire credential lifetime.

The reduction begins with the real attack game G_0. Game G_1 aborts on any hash-output or nonce collision; the birthday terms below bound the statistical difference from G_0. Game G_2 additionally aborts when an active send contains a valid authenticator whose corresponding random-oracle input was never queried. Such an event is a direct tag forgery, bounded by the hash length and number of active sends. A previously accepted authenticator is instead rejected by the replay cache and cannot create a new accepted instance. In G_3, the test key is replaced by an independent random value unless the adversary queried $h(X \| Y)$ for the tested session.

Producing that final query requires reconstructing the long-term masking path, testing CEAF responses against a recorded Q_1, obtaining an accepted CEAF live response, or forging a preceding authenticator. Password and biometric uncertainty is collected in p_{cred}, while online CEAF attempts appear separately because they are verified by EN and controlled by ctr_i; the union of offline and live CEAF tests contributes $q_{\mathrm{CEAF}}/26^s$, with the live component bounded only by the deployment's source/global admission policy. Define $\varepsilon_{\mathrm{cred}} = \min\{1, 2p_{\mathrm{cred}}(q_g)\}$ and $\varepsilon_{\mathrm{CEAF}} = \min\{1, 2q_{\mathrm{CEAF}}/26^s\}$. Applying the triangle inequality across the games gives $\mathrm{Adv}^{\mathrm{ror}}_{\Pi}(\mathrm{A}) \le \frac{q_h(q_h-1)}{2^{l_h}} + \frac{q_n(q_n-1)}{2^{l_n}} + \frac{2q_s}{2^{l_h}} + 2p_{\mathrm{cred}}(q_g) + \frac{2q_c}{26^s}$.

$$\mathrm{Adv}^{\mathrm{ror}}_{\Pi}(\mathrm{A}) \le \min\left\{1,\ \frac{q_h(q_h-1)}{2^{l_h}} + \frac{q_n(q_n-1)}{2^{l_n}} + \frac{2q_s}{2^{l_h}} + \varepsilon_{\mathrm{cred}} + \varepsilon_{\mathrm{CEAF}}\right\}. \tag{2}$$

The bound makes two limits explicit. First, the CEAF contributes only $s \log_2 26 = 14.10$ bits at the selected parameters, so rate control is part of the online-guessing argument; a recorded transcript permits offline enumeration, while source/global admission control applies only to live attempts. Second, overall security still depends on password distribution and biometric min-entropy rather than on the hash length alone. The outer minimum enforces the defining ROR range $\mathrm{Adv} \le 1$; once $q_{\mathrm{CEAF}} \ge 26^s/2$, the CEAF term saturates at the trivial bound rather than exceeding it. The main protocol excludes post-session long-term compromise. A complete proof of the PFS sketch would replace recovery of the tested key with a CDH challenge and would include a term of the form $2\,\mathrm{Adv}^{\mathrm{CDH}}_{E}(\mathrm{B})$.

In the residual-CEAF three-credential experiment, (SC, PW, BIO) are known and the tested CEAF state is not. The credential term in the preceding general bound is therefore replaced by the online term, giving $\mathrm{Adv}^{\mathrm{3cred}}_{\Pi}(\mathrm{A}) \le \frac{q_h(q_h-1)}{2^{l_h}} + \frac{q_n(q_n-1)}{2^{l_n}} + \frac{2q_s}{2^{l_h}} + \frac{2q_c}{26^s}$. For recorded transcripts, q_e offline response tests replace the password/biometric term; live attempts additionally contribute q_c, with $q_e + q_c \le q_h$. The resulting bound is

$$\mathrm{Adv}^{\mathrm{3cred}}_{\Pi}(\mathrm{A}) \le \min\left\{1,\ \frac{q_h(q_h-1)}{2^{l_h}} + \frac{q_n(q_n-1)}{2^{l_n}} + \frac{2q_s}{2^{l_h}} + \varepsilon_{\mathrm{CEAF}}\right\}. \tag{3}$$

This is a bounded online-guessing enumeration-and-online-guessing statement, not a claim that of offline resistance after exposure of the other three credentialsleaves full-strength security.

To complement the symbolic ROR argument, a supplied HLPSL abstraction of the core M_1–M_4 exchange returned SAFE with both AVISPA OFMC and CL-AtSe under bounded sessions (OFMC: four visited nodes at depth three; CL-AtSe: eight analyzed and three reachable states, typed model). The abstraction targets message-level secrecy and authentication; offline CEAF enumeration, source/global rate control, two-record recovery, M_5–M_6 retry, TEE extraction, and human usability remain outside its scope.

5.2 Protocol-Level Security Audit

The following audit interprets the formal results at protocol level. It distinguishes prevention from mitigation, identifies what a captured party reveals about itself, and records negative results rather than marking every property as satisfied. These qualifications determine the entries and footnotes in Table 3.

5.2.1 Resistance to First-Factor Recovery

Q_1 binds the fresh challenge, CEAF response, target sensor, pseudo-identity, nonce, and timestamp. *EN* reconstructs that input with edge-only state, so The card does not store a CEAF verifier, but a recorded Q_1 can be tested offline after the card, password, and biometric do not provide a local CEAF verifier; an attacker holding them must submit guesses to are exposed; live attempts are still checked at *EN* and are subject only to deployment source/global admission limits. The response state changes advances only after confirmation, preventing so a dropped attempt from advancing cannot move one side prematurely. As Section 3.1.3 states, however, notes, two consecutive observations recover the CEAF state, and exposure of the other three credentials leaves only a rate-controlled 14.10-bit online search. the protocol therefore makes no offline-resistance claim under three-credential compromise.

SC stores five masked fields but no CEAF state. Recovering R_i requires UID_i, ID_{SC}, and the reproduced biometric secret R_U; recovering TC_i additionally requires the password-dependent HPW. Thus card compromisealone requires joint password and biometric guessing and does not reveal the CEAF vector. If the card and biometric are both exposed, *RPW* provides an offline check for password guesses; if the card and password are exposed, it analogously checks biometric guesses. These two-credential cases are represented by p_{cred} rather than described as unconditional offline-guessing resistance.

Recovering $SK = h(X \| Y)$ from traffic requires a long-term masking path or tag forgery, bounded in Section 5.1.1. If (R_i, TC_i) is exposed, each online CEAF guess succeeds with probability 26^{-s}. One pre-cooldown interval gives $\rho/26^s = 2.85 \times 10^{-4}$ at $(\rho, s) = (5, 3)$; over a longer interval the bound is $q_c/26^s$, not a lifetime cap. The scheme therefore mitigates online guessing through rate policy rather than providing an unconditional prevention claim.

5.2.2 Resistance to Sensor-Node Capture

Capturing SN_j reveals both its stored masked credentials and, with an observed current PID_j, that node's TC_j. The adversary can therefore ; the adversary can then attack current or future sessions of the captured node until revocation; the protocol does not claim otherwise, and the protocol claims no more. Because every sensor uses an independently sampled R_j and a separate TC_j, this information does not reconstruct another sensor's credential. , so A4 therefore concerns containment of lateral compromise to uncaptured nodes.

5.2.3 Session-Key Independence and the Absence of Perfect Forward Secrecy

Each Q binds the fields reconstructed at its receiver rather than merely the values sent in clear. Changing a masked nonce, pseudo-identity, challenge seed, target sensor, or timestamp consequently changes the verifier's hash input. An altered message is accepted only if the adversary knows the effective secret or produces a random-oracle forgery, bounded by $q_s/2^{l_h}$.

Timestamp windows reject messages outside the acceptance interval, while the atomic cache keys defined in Section 4.4 reject duplicates that remain inside it. An attacker cannot refresh an old transcript by changing TS because every timestamp is included in the corresponding Q. A message without its unique pending context is rejected, and the single-session rule prevents concurrent executions from applying two transitions to one credential version.

Syntax, identifier, and timestamp checks reject malformed or stale traffic before CEAF evaluation. Nevertheless, valid-looking messages can consume edge lookup, hashing, and state resources, and distributed sources can evade a per-source limit. Source/global rate limits and the non-extending cooldown therefore mitigate rather than prevent DDoS; A8 is conservatively N. The two-record state addresses message loss and must not be interpreted as a DDoS proof.

Q_1 authenticates U's four credentials to EN; Q_2, Q_3 authenticate EN and SN under TC_j; Q_4 proves knowledge of both nonces. Because EN and SN both know them, attribution at U relies on the honest-relay assumption. Remaining impersonation probability follows Section 5.1.1.

PID_i, PID_j, and masked PID_{SN} hide real identities from a passive observer of either public channel and rotate after successful authentication. The masks depend on fresh nonces or long-term values unavailable to the channel adversary. Registration and routing still expose identities and the user–sensor association to trusted EN, so the claim is channel anonymity rather than anonymity from the intermediary.

Freshly rotated pseudo-identities make completed runs passively unlinkable when the adversary only observes traffic. An active adversary can drop M_4, causing LD to retain the previous PID_i while EN accepts it through the recovery window. The next run is then linkable to the dropped run, although the real identity remains hidden. Table 3 marks this qualified property with a footnote rather than claiming unconditional unlinkability.

Fresh independent (X, Y) give session-key independence. However, a recorded transcript plus independence: before long-term compromise, keys from separate accepted sessions are independent even when transcripts are public. This is weaker than perfect forward secrecy. A recorded transcript together with later (R_i, TC_i) or the edge record containing R_{EN} and PK_i recovers both nonces and past keys, so the main protocol lacks PFS. It ; it protects SK from the channel a channel-only adversary, not from trusted EN. Section gives a conditional design sketch for adding PFS and honest-but-curious edge opacity; those properties are not attributed to the main protocol or claimed as a complete proofThus A12 in Table 3 must not be read as an A13 claim.

Without two-record state, dropping M_3 or M_4 leaves adjacent principals on different rotating credentials. The version-bound (cur, $prev$) lookup, previous-offset retry, replay cache, and single-session rule absorb one lost M_1–M_4 without accepting duplicate or mixed-version state. This does not cover M_5–M_6; loss of M_6 after edge commit can require authenticated recovery or re-registration.

6 Comparison and Analytical Evaluation

We compare security properties with Li and Wang [54], Li et al. [24], Far et al. [34], and Xu et al. [25]. Their three-tier architectures are sufficiently close for a qualified property comparison. Quantitative cross-protocol rankings are not reported because the papers use different operation sets, hardware platforms, point sizes, and storage-inclusion rules; reproducing them under one verified implementation is outside the present analytical study.

6.1 Security-Property Comparison

Table 3 reports A12–A15 separately: key independence, PFS, update resilience, and edge-node key opacity.

Entries follow the original attack analyses and update procedures rather than a simple count of claimed features. A1 requires a cognitively evaluable factor that is verified remotely, not merely a dynamic identifier. A12 denotes independence of fresh session keys, whereas A13 requires resistance to later long-term compromise. A15 asks whether the authenticating intermediary can derive the endpoint key.

Far et al.'s PFS entry assumes erasure of its ephemeral value; its update is not recoverably synchronised synchronized and its gateway derives the key. Xu et al. provide A13–A15 under their ECC construction.

Table 3: Security-property comparison.

Property	Li and Wang [54]	Li et al. [24]	Far et al. [34]	Xu et al. [25]	Ours PFS sketch
A1	N	N	N	N	Y Y
A2	Y	Y	Y	Y	Y P[a] Y[a]
A3	Y	Y	Y	Y	Y P[b] Y[b]
A4	Y	Y	Y	Y	Y P[c] Y[c]
A5	N	Y	Y	Y	Y Y
A6	Y	Y	Y	Y	Y Y
A7	Y	Y	Y	Y	Y Y
A8	N	N	Y	Y	N N
A9	Y	Y	Y	Y	Y P[d] Y[d]
A10	Y	Y	Y	Y	Y P[e] Y[e]
A11	Y	Y	Y	Y	Y≦ Y≦ P[f]
A12	Y	Y	Y	Y	Y Y
A13	Y	Y	Y§ [g]	Y	N C
A14	Y	Y	N	Y	Y≧ Y≧ P[h]
A15	Y	Y	N	Y	N C

Y denotes the property under the stated model; P denotes a partial or qualified property; N denotes that the property is not provided. A1: cognitively evaluable authentication credential verified remotely; A2: smart-card theft and offline guessing; A3: online guessing; A4: sensor capture; A5: three-factor authentication; A6: message integrity; A7: replay; A8: DDoS; A9: mutual authentication and impersonation; A10: anonymity; A11: tracking; A12: session-key independence; A13: PFS; A14: desynchronization; A15: opacity to the authenticating intermediary. [a] Card-only compromise requires joint guessing; card plus password or biometric permits offline guessing of the remaining credential. With (SC, PW, BIO) exposed, a recorded Q_1 also permits offline CEAF enumeration. [b] A single admitted CEAF guess succeeds with probability 26^{-s}; over q_c admitted online trials, the union-bound success probability is at most $\min\{1, q_c/26^s\}$. The corresponding ROR advantage contribution is $2\min\{1, q_c/26^s\}$, while the full reduction also includes offline tests q_e. [c] The captured node remains compromised; P denotes containment of lateral compromise to other nodes. [d] Attribution at U assumes an honest trusted relay. [e] Anonymity is from the public channel, not from EN. [f] P denotes passive unlinkability only; an active drop can link adjacent runs while the real identity remains hidden. [g] Follows the source paper's erasure assumption. [h] P covers M_1–M_4, authenticated sensor resynchronization, and the bounded authenticated M_5–M_6 retry, not arbitrary repeated loss.

Our main protocol deliberately lacks A13 and A15. The PFS column records only conditional properties of the design sketch, not a completed proofIts A2/A3 entries are qualified because a recorded Q_1 enables offline CEAF enumeration after three-credential exposure, while live attempts are subject to deployment source/global limits. Our A14 covers only the normal M_1–M_4 , and rate limiting or cooldown exchange, authenticated sensor resynchronization, and the bounded authenticated retry of M_5–M_6; rate limiting does not justify marking A8 as full DDoS resistance.

Cui et al. [26] provide message authentication without a comparable session key; Shang et al. [27] use two parties without a user or smart card. They are therefore excluded from the three-party tables.

6.2 Analytical Overhead of the Proposed Scheme

We report computation, communication, and storage for the proposed exchange only. The values describe one complete login and AKA session; registration, occasional credential update, replay caches, and session locks are excluded. The PFS sketch is shown separately so that its conditional security properties are not combined with the main protocol's lower operation count.

6.2.1 Cost Model and Overhead

We neglect random generation, timestamps, XOR, display, and character shifts in the cryptographic-operation estimate. Challenge expansion is retained. Its expected cost is analytical count; challenge expansion has expected cost

$2.000008T_H$, rounded to $2T_H$. Secrets, nonces, hashes, and identities are modelled modeled as 160 bits , and timestamps as 32 bits , and compressed curve points as 320 bits [69–72]. Table states under the H_{160} field profile defined in Section 3.1. With illustrative unit costs used only to convert operation counts into an internal estimate; they are not measurements from an implementation of this protocol.

Illustrative unit-cost assumptions (not measured in this study). **Operation Definition Execution Time (ms)**T_H Hash function 0.0004T_E Elliptic-curve point multiplication 0.442T_F Fuzzy reproduction (assumed equal to T_E)0.442

Table derives an illustrative $T_H = 0.0004$ ms and $T_F = 0.442$ ms, the main protocol is analytically estimated at $15T_H + T_F + 21T_H + 6T_H = 42(0.0004) + 0.442 = 0.4588$ ms. This 0.4588 ms value is an illustrative analytical estimate, not an implementation benchmark. We additionally ran the reference implementation in `benchmarks/benchmark_protocol.py` for 200,000 iterations on a Windows 10 host with an AMD Ryzen 7 7800X3D 8-core processor (16 logical CPUs), Python 3.14.2, and the OpenSSL-backed `hashlib` SHA-256 implementation. The median time of one full 64-byte SHA-256 operation was $T_H^{\text{host}} = 0.000425$ ms (p95 0.000454 ms); protocol-field truncation to 160 bits is applied after the hash operation. The reference 256-byte fuzzy reproduction was $T_F^{\text{host}} = 0.004376$ ms (p95 0.004569 ms). The resulting role medians were 0.011004 ms estimate for the hash-dominated main protocol. Most of this value is the assumed fuzzy-reproduction cost at for LD ; challenge expansion is included in the hash count. Four point multiplications raise the arithmetic estimate for the PFS sketch to 2.2268(15 hashes plus reproduction), 0.008994 ms. The latter is ms for EN (21 hashes), and 0.002625 ms for SN (6 hashes), whose sum is 0.022624 ms. This is a lower-bound operation countbecause point decoding, validation, host-software measurement, not a constrained-board, energy, or network benchmark; the fuzzy-reproduction value is implementation-dependent because the manuscript does not mandate a specific error-correcting fuzzy extractor. As an interim constrained-device calibration, Ledwaba et al. measured full SHA-256 on a Cortex-M4 at 57.361 μs/hash, 114.615 mW, and 3.56 kB of RAM [56]. The reported 114.615 mW is power, not per-hash energy; therefore, we first compute $E_H^{\text{M4}} = P_H t_H = 114.615\,\text{mW} \times 57.361\,\mu\text{s} = 6.574\,\mu\text{J} = 0.006574$ mJ per hash, and then multiply by the role-specific hash counts. This gives the SHA-only estimates in Table 4, with the LD fuzzy-reproduction time and energy left as T_F and subgroup checks are not specified or pricedE_F. These are literature-calibrated estimates rather than measurements of this protocol; they exclude fuzzy extraction, I/O, radio, scheduling, compiler, and board-specific effects. Communication is 2048 bits for a normal session and static state is 2880 bits for $m = n = 1$ under the 160-bit field profile; an edge domain with m users and n sensors stores $160 + 800m + 640n$ bits at EN. The exceptional resynchronization exchange is excluded from the normal-session communication count. These counts exclude link, transport, retransmission, certificate, replay-cache, lock, and rate-limit overheads.

6.3 Sensitivity of the Guardrail Parameters

Because the residual attack surface of the scheme live attack surface is the online CEAF termrather than an offline one, the deployment parameters that shape that term deserve to be reported rather than fixed silently. The three that matter are reported explicitly. The two protocol-relevant quantities are the segment count s, which fixes the response space 26^s; the consecutive-failure limit ρ, which fixes how many attempts precede a cooldown; and the accepted , and the admitted online attempt budget q_c of Section 5.1.1. The values below are computed from the expressions already derived and are not measurements; they characterise the policydescribe the security budget, not an implementation.

Table 5 varies s at $\ell = 7$and $\rho = 5$. The pre-cooldown success probability $\rho/26^s$ falls by a factor of 26 per added segment. The success probability of one admitted CEAF guess is 26^{-s}, and the number of guesses needed for an even chance of one success grows as $26^s \ln 2$. The rightmost columns translate that into a policy statement: at an illustrative fixed cooldown of 15 minutes, an adversary holding (R_i, TC_i) and doing nothing but guessing needs on the order of a month of sustained attempts at

Table 4: Analyticalcomputation , host-measured, and literature-calibrated overhead of the proposed exchange. Communication and static-state entries use the 160-bit field profile; the 0.4588 ms value is an illustrative analytical estimate, host timing is a reference software measurement, and the Cortex-M4 row is a SHA-only estimate rather than a protocol benchmark.

(a) Computation

Scheme	U	EN	SN	Total Analytical (ms)	Host median (ms)
Ours	$15T_H + T_F$	$21T_H$	$6T_H$	0.4588 PFS sketch*	$15T_H + T_F + 2T_E$ $21T_H$ $6T_H + 2T_E$ 2.22680.0226

Table derives 2048 bits for the main protocol, including the 160-bit masked challenge seed in M_1. The PFS sketch adds one 320-bit point to each message and therefore reaches 3328 bits. These are message-size calculations, not measured network traffic; link, transport, retransmission, and certificate overheads are excluded.

Message-size derivation for the proposed exchange (bits). **(b) Communication (bits)**

MessageMsg	Route	Bit accountingAccounting	MainPFS sketch
M_1	$LD \to EN$ $LD \to EN$	$5(160) + 32$	8321152
M_2	$EN \to SN$ $EN \to SN$	$3(160) + 32$	512832
M_3	$SN \to EN$ $SN \to EN$	$2(160) + 32$	352672
M_4	$EN \to LD$ $EN \to LD$	$2(160) + 32$	352672
Total			20483328

For the analytical inventory in Table , the fuzzy-extractor helper P_U and the failure counter are instantiated as 160 and 32 bits, respectively. Each SC/LD stores five 160-bit fields. Each EN user record costs $5(160) + 32 = 832$ bits, each sensor record costs $3(160) = 480$ bits, and the domain stores one 160-bit R_{EN}, so an edge domain with m users and n sensors requires $160 + 832m + 480n$ bits at EN. Each SN stores two 160-bit masked credentials. Table shows the base case $m = n = 1$. Provisioned public identities, program code, timers, replay caches, locks, and rate-limit tables are excluded. An implementation with longer fuzzy helper data must add the difference to each SC/LD and the total.

Static cryptographic-state inventory (bits). **(c) Static cryptographic state (bits)**

Scope	SC/LD	EN	SN	Total
One-domain base Base case ($m = n = 1$)	800	1472 1440	320 640	25922880

(d) Literature-calibrated Cortex-M4 estimate (SHA-only)

Role	SHA-256 calls	Time / energy (ms / mJ)	RAM reference
LD	15	$0.860 + T_F$ / $0.099 + E_F$	3.56 kB
EN	21	1.205 / 0.138	3.56 kB
SN	6	0.344 / 0.039	3.56 kB

The estimates apply $E_H = P_H t_H$ to the full-SHA-256 time and power reported for a Cortex-M4 in [56]; the reported power is not treated as an energy value, and E_F is not estimated because the protocol leaves the fuzzy extractor implementation open.

$s = 3$ and years at $s = 4$. The cost of raising Raising s is borne almost entirely by the user , who makes s column selectionsper login instead of $s - 1$; the mainly increases user selections; transmitted size is unchanged because only the 160-bit seed σ travels, and the computational effect is confined to challenge expansion , whose expected block count is given in the last column and stays within one additional T_H across the whole rangeand challenge expansion adds less than one hash block.

Varying ρ at $s = 3$ moves the pre-cooldown probability linearly: 1.71×10^{-4} at $\rho = 3$, 2.85×10^{-4} at $\rho = 5$, 5.69×10^{-4} at $\rho = 10$, and 1.14×10^{-3} at $\rho = 20$. The choice is therefore a direct trade against usability, since ρ is also the number of honest mistakes tolerated before a legitimate user is delayed, and it is the parameter a deployment should tune first.

The budget q_c behaves differently, and its behaviour is the reason the this behavior is why the scheme is described as rate-controlled rather than as unconditionally resistant. The online term $2q_c/26^s$ is informative only while $q_c \ll 26^s/2$; at $s = 3$ it reaches unity at roughly 8.8×10^3 accepted attemptsagainst one user recordadmitted attempts, and at $s = 4$ at roughly 2.3×10^5. Since nothing in the primitive caps q_c over a credential lifetime, the guarantee rests on the deployment enforcing per-record, per-source, and global limits , source/global limits and on credential update resetting the state. A deployment that logs but does not bound accepted admitted attempts

Table 5: Analytical sensitivity of the online CEAF term to the segment count ($\ell = 7$, $\rho = 5$).

s	L	26^s	Bits	$\rho/26^s$ One-guess probability	Cooldown intervals Guesses for 50%	$\mathbb{E}$[blocks]	Provisional guidance
2	14	676	9.40	7.40×10^{-3} 1.48×10^{-3}	9.4×10^{1} (≈ 1 day) 4.7×10^{2}	1.065	Provisional; low burden; weaker protection
3	21	17,576	14.10	2.85×10^{-4} 5.69×10^{-5}	2.4×10^{3} (≈ 25 days) 1.2×10^{4}	2.000	Provisional; validate budget/workflow
4	28	456,976	18.80	1.09×10^{-5} 2.19×10^{-6}	6.3×10^{4} (≈ 1.8 years) 3.2×10^{5}	2.027	Provisional; stronger; training advised
5	35	11,881,376	23.50	4.21×10^{-7} 8.42×10^{-8}	1.6×10^{6} (≈ 47 years) 8.2×10^{6}	2.787	Provisional; high burden; trained only

The final column is provisional deployment guidance, not an empirical usability conclusion. The guess counts are $26^s \ln 2$ and assume independent admitted attempts; they are policy arithmetic, not measurements. The final value of s should be selected jointly with the admitted-attempt budget q_c, observation environment, and target workflow. Human error rates under larger s are not modeled and require the usability study identified in Section 7.

obtains no security from this term regardless of s, which is the practical form of the negative result recorded in Sections 3.1.3 and 5.25.

These values report only operation counts, message sizes, static storage, and the policy arithmetic of Section 6.3. They do not rank protocols or measure latency, throughput, queueing, usability, or load resilience. Such results depend on the implementation, radio, retransmission policy, topology, processor allocation, and edge service, and they would be misleading if reported from an operation-count model. We state the missing measurements explicitly so that the boundary is not mistaken for a claim: an implementation on constrained edge hardware with a TEE, giving authentication latency and energy per session under concurrent load; the added delay the guardrail imposes on a query that reaches the inference service behind it; the behaviour of the cooldown and rate limiter under a distributed campaign of valid-looking messages; and an end-to-end comparison in which an automated credential attack is run against a scheme with a local verifier and against the present one, measuring accepted sessions per unit of adversary compute rather than per guess. That last experiment is the one that would convert the central argument of this paper from an analytical statement into an empirical one, and it is the first item of our ongoing work.

7 Conclusions

We addressed dynamic credentials, multi-credential authentication, and lightweight three-party AKA for edge-intelligent IIoT, where one node is at once the local inference point and the access-control point in front of it. The proposed . CEAF converts a fresh public challenge and an evolving memorized vector into a session response that is response collected by LD but verified at EN. After exposure of and bound into Q_1. After the password, smart card, and biometric , an attacker still has no local CEAF verifier but can make rate-controlled online guesses with success $q_c/26^s$. This is the sense in which the scheme answers an automated adversary: it does not make the first three credentials harder to break, it removes the offline verifier that would let a faster attacker convert that break into an accepted session. The main protocol remains hash dominated, and its are exposed, a recorded Q_1 still permits enumeration of the 26^s responses; live attempts remain subject to source/global limits with per-attempt success 26^{-s}. The scheme therefore makes no offline-resistance claim under three-credential compromise. Its contribution is transcript binding, explicit attack accounting, and

a version-bound two-record state , replay cache, and single-session rule recover one lost message in that recovers one lost M_1–M_4 message and invokes authenticated sensor resynchronization after repeated sensor-side loss.

BAN-style correspondences delimit message attribution, while the The ROR reduction makes credential quality, CEAF guessingenumeration, collisions, and forgery terms explicit. The analysis also records negative results: the main protocol AVISPA reports return SAFE for the bounded core model; the main protocol nevertheless provides session-key independence but neither PFS nor key opacity from the trusted edge node. An authenticated elliptic-curve design sketch conditionally addresses both properties for four point multiplications and 1280 additional transmitted bits, but it is not claimed as a complete protocol proof. Under the illustrative analytical model , the main protocol is estimated at The illustrative model gives 0.4588 ms, the host reference implementation gives a 0.0226 ms and communicates 2048 bits; no empirical sum of role medians, and the Cortex-M4 calculation in Table 4 is a SHA-only literature estimate; none is a complete constrained-device or cross-protocol performance rankingis claimed. Section 6.3 reports how the residual online term moves with the segment count, the failure limit, and the accepted attempt budget, and identifies the budget rather than the primitive as the binding constraint on a deployment.

Several limitations remain. ranking. Password and CEAF are both knowledge credentialsrather than independent factor categories. Two consecutive successful remain knowledge credentials, and two consecutive observations reveal the CEAF step and later responses [57], and the selected cognitive workflow still requires usability testing. That limitation deserves particular attention under the automated adversary assumed in Section 3.4, because camera capture with automatic transcription of the displayed columns makes two consecutive observations far cheaper than manual shoulder surfing. The [57]; the one-observation bound is thus a modelling assumption and not a property the protocol enforces; display-side countermeasures such as narrow-viewing-angle rendering of the candidate columns, or independent refresh of each segment, are the natural next step and are not analysed hereenvironmental, not cryptographic. EN is a high-value trust anchorbecause it stores all CEAF records and derives the main-protocol session keyremains a trusted key-derivation anchor. The two-record invariant applies only to absorbs one lost M_1–M_4 ; the message, authenticated resynchronization repairs repeated sensor-side loss, and bounded M_5–M_6 credential update is not loss-atomic and may require authenticated recovery after a lost acknowledgement. Finally, implementation benchmarks, the experiments listed at the end of Section 6, and comparisons with edge-native schemes having different party or trust models [26,27] remain future work. retry handles one lost update acknowledgement.

A last point of positioning. The scheme is one layer of an edge-intelligent deployment and it is deliberately the outermost one: it decides admission to the query interface and to the ingestion path, and it makes that decision hard to automate away, but it says nothing about the behaviour of the model once a caller has been admitted. Prompt injection, poisoning, adversarial examples, and query-based extraction remain the responsibility of the model-level defences of Section 2.3, and Table 1 keeps that division explicit. The contribution we claim is that an access-control layer designed against an adversary whose offline work is automated leaves a residual surface that a deployment can actually meter, which is the precondition those other defences implicitly assume and rarely stateThree concrete validation and mitigation paths follow from these boundaries. First, we will port the reference implementation to an ESP32-class board using an mbedTLS SHA-256 implementation, fix the clock/compiler configuration, and report cycle counts, RAM/flash use, current, and energy for each role; the present Cortex-M4 calculation is an interim calibration, not a substitute for that experiment. Second, a small usability pilot will measure completion time and error rate for the randomized $s = 3$ display before any deployment claim is made; no human-error statistic is asserted here. Third, an optional secure-element-held or login-device-TEE-held, non-extractable user-side HMAC key could be bound into Q_1 to prevent a recorded transcript from being tested with only (SC, PW, BIO), but that changes the credential architecture and requires a new proof and usability assessment. At the deployment layer, a stateless challenge/SYN-cookie-like admission token, source and global token buckets, concurrency caps, and replay filtering can reduce resource-exhaustion pressure [53]; these mechanisms mitigate rather than eliminate distributed DoS.

Acknowledgement: Not applicable.

Funding Statement: This research was funded by the National Natural Science Foundation of China, grant numbers 62272389 and 62372069.

Author Contributions: Xun Zhang: Conceptualization, Methodology, Validation, Formal analysis, Writing—original draft preparation, Funding acquisition; Zhiying Mu: Methodology, Investigation; Wu Wei: Validation, Formal analysis, Writing—review and editing; Zhihui Mu: Validation, Formal analysis, Writing—review and editing; Dejun Mu: Conceptualization, Validation, Writing—review and editing, Supervision, Funding acquisition; Xin Liu: Conceptualization, Validation, Writing—review and editing, Supervision, Funding acquisition. All authors reviewed and approved the final version.

Availability of Data and Materials: The reproducibility package is supplied as Supplementary Files S1–S6 and mirrored at the public GitHub repository. The repository contains the benchmark script and results under `benchmarks/` and the HLPSL model, latest AVISPA report, and WSL instructions under `avispa/`. The benchmark routine uses a deterministic 256-byte sample, a 16-byte salt, a SHA-256 helper digest, and two HMAC-SHA-256 calls as a reproducible timing surrogate; it is not a mandated error-correcting fuzzy extractor. The supplied results are reproducible subject to platform differences.

Ethics Approval: Not applicable.

Conflicts of Interest: The authors declare no conflicts of interest.

References

1. Shi W, Cao J, Zhang Q, et al. Edge computing: vision and challenges. IEEE Internet Things J. 2016;3:637-46.
2. Ranaweera P, Jurcut AD, Liyanage M. Survey on multi-access edge computing security and privacy. IEEE Commun Surv Tutor. 2021;23:1078-124.
3. Srinivas J, Mishra D, Mukhopadhyay S, et al. Provably secure biometric based authentication and key agreement protocol for wireless sensor networks. J Ambient Intell Humaniz Comput. 2018;9:875-95.
4. Jabbari A, Mohasefi JB. Improvement of a user authentication scheme for wireless sensor networks based on internet of things security. Wirel Pers Commun. 2021;116:2565-91.
5. Wu F, Xu L, Kumari S, et al. A privacy-preserving and provable user authentication scheme for wireless sensor networks based on internet of things security. J Ambient Intell Humaniz Comput. 2017;8:101-16.
6. Adil M, Almaiah MA, Omar Alsayed A, et al. An intelligent hybrid mutual authentication scheme for industrial internet of thing networks. Comput Mater Contin. 2021;68:447-70.
7. Wang D, Hong S, Wang Q. Revisiting a multifactor authentication scheme in industrial IoT. Secur Commun Netw. 2021;2021:9995832.
8. Singh J, Gimekar A, Venkatesan S. An efficient lightweight authentication scheme for human-centered industrial internet of things. Int J Commun Syst. 2023;36:e4189.
9. Shuai M, Xiong L, Wang C, et al. A secure authentication scheme with forward secrecy for industrial internet of things using Rabin cryptosystem. Comput Commun. 2020;160:215-27.
10. Rangwani D, Sadhukhan D, Ray S, et al. A robust provable-secure privacy-preserving authentication protocol for industrial internet of things. Peer-to-Peer Netw Appl. 2021;14:1548-71.
11. Basharzad SN, Fazeli M. Knowledge based dynamic password. In: Proceedings of the IEEE 4th International Conference on Knowledge-Based Engineering and Innovation; 2017. p. 367-72.
12. Liu X, Zhang RS, Zhao MQ. A robust authentication scheme with dynamic password for wireless body area networks. Comput Netw. 2019;161:220-34.
13. Shakirov B, Kim H, Lee K, et al. Analysis on vulnerability of password entry using virtual onscreen keyboard. J Korea Inst Inf Secur Cryptol. 2016;26:857-69.
14. Khalid Z, Paul P, Chattopadhyay SP, Biswas AN. Secure authentication with dynamic password. In: Proceedings of the 7th IEEE Annual Information Technology, Electronics and Mobile Communication Conference; 2016. p. 1-7.
15. Hitaj B, Gasti P, Ateniese G, Perez-Cruz F. PassGAN: a deep learning approach for password guessing. In: Applied Cryptography and Network Security (ACNS 2019). vol. 11464 of Lecture Notes in Computer Science; 2019. p. 217-37.
16. Xu M, Yu J, Zhang X, Wang C, Zhang S, Wu H, et al. Improving real-world password guessing attacks via bi-directional transformers. In: Proceedings of the 32nd USENIX Security Symposium; 2023. p. 1001-18.
17. Tolosana R, Vera-Rodriguez R, Fierrez J, Morales A, Ortega-Garcia J. DeepFakes and beyond: a survey of face manipulation and fake detection. Inf Fusion. 2020;64:131-48.
18. Kong DK, Wang XZ, Zhong LX, et al. Dynamic password token based on SM3 algorithm. In: Proceedings of the 5th International Conference on Audio, Language and Image Processing; 2016. p. 180-4.
19. Yusuf SI, Boukar MM, Mukhtar A, Yusuf AD. User define time based change pattern dynamic password authentication scheme. In: Proceedings of the 14th International Conference on Electronics, Computer and Computation; 2018. p. 206-12.
20. Chen L, Kurniati T, Wu ZY, et al. Using dynamic passwords for the exchange and sharing of personal health records: a reliable user authentication scheme. J Internet Technol. 2020;21:1049-59.
21. Turkanović M, Hölbl M. An improved dynamic password-based user authentication scheme for hierarchical wireless sensor networks. Electron Electr Eng. 2013;19(6):109-16.
22. Amin R, Biswas GP. A secure light weight scheme for user authentication and key agreement in multi-gateway based wireless sensor networks. Ad Hoc Netw. 2016;36:58-80.
23. Li X, Niu J, Kumari S, et al. A three-factor anonymous authentication scheme for wireless sensor networks in internet of things environments. J Netw Comput Appl. 2018;103:194-204.
24. Li X, Niu J, Bhuiyan MZA, et al. A robust ECC-based provable secure authentication protocol with privacy preserving for industrial internet of things. IEEE Trans Ind Inform. 2018;14:3599-609.
25. Xu H, Hsu CF, Harn L, et al. Three-factor anonymous authentication and key agreement based on fuzzy biological extraction for industrial internet of things. IEEE Trans Serv Comput. 2023;16:3000-13.
26. Cui J, Wang F, Zhang Q, et al. An anonymous message authentication scheme for semi-trusted edge-enabled IIoT. IEEE Trans Ind Electron. 2021;68:12921-9.
27. Shang W, Wen X, Chen Z, et al. Lightweight authentication scheme for edge control systems in industrial internet of things. Front Inf Technol Electron Eng. 2024;25:1466-78.

28. Wong KHM, Zheng Y, Cao JN, et al. A dynamic user authentication scheme for wireless sensor networks. In: Proceedings of the IEEE International Conference on Sensor Networks, Ubiquitous, and Trustworthy Computing; 2006. p. 244-51.
29. Das ML. Two-factor user authentication in wireless sensor networks. IEEE Trans Wirel Commun. 2009;8:1086-90.
30. Paliwal S. Hash-based conditional privacy preserving authentication and key exchange protocol suitable for industrial internet of things. IEEE Access. 2019;7:136073-93.
31. Turkanović M, Brumen B, Hölbl M. A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the internet of things notion. Ad Hoc Netw. 2014;20:96-112.
32. Jiang Q, Ma JF, Wei FS, et al. An untraceable temporal-credential-based two-factor authentication scheme using ECC for wireless sensor networks. J Netw Comput Appl. 2016;76:37-48.
33. Liu X, Guo Z, Ma J, et al. A secure authentication scheme for wireless sensor networks based on DAC and Intel SGX. IEEE Internet Things J. 2022;9(5):3533-47.
34. Abdi Nasib Far H, Bayat M, Das AK, et al. LAPTAS: lightweight anonymous privacy-preserving three-factor authentication scheme for WSN-based IIoT. Wirel Netw. 2021;27:1389-412.
35. Mohamed N, Al-Jaroodi J. Security applications of edge intelligence. In: Proceedings of the 2023 IEEE World AI IoT Congress (AIIoT). Seattle, WA, USA; 2023. p. 508-12.
36. Xu Y, Mao Y, Li J, Chen X, Wu S. Edge server enhanced secure and privacy preserving federated learning. Comput Netw. 2024;249:110465.
37. Wang K, Dong J, Xu Y, Ji X, Sha L, Xiao F. READ: resource efficient authentication scheme for digital twin edge networks. Future Gener Comput Syst. 2025;163:107498.
38. Xiao Z, Chen Y, Li T, Tian S, Min G, Tang Z, et al. Toward Secure Task Offloading in Vehicular Edge Computing Networks. IEEE Transactions on Dependable and Secure Computing. 2026;23(5):9963-77.
39. Sun G, Liao D, Zhao D, Xu ZE, Yu H. Live Migration for Multiple Correlated Virtual Machines in Cloud-based Data Centers. IEEE Transactions on Services Computing. 2018;11(2):279-91.
40. Zhang Y, Feng S, Wang P, Tan Z, Luo X, Ji Y, et al. Learning Self-Growth Maps for Fast and Accurate Imbalanced Streaming Data Clustering. IEEE Transactions on Neural Networks and Learning Systems. 2025;36(9):16049-61.
41. Yue M, Cui H, Gao T, Wu Z, Zheng H. ADS-B Tree-Chain: A Tree-Chain Authentication Scheme for Protecting ADS-B Data Security. IEEE Transactions on Aerospace and Electronic Systems. 2026;62:4525-39.
42. Zhang L, Ye Q, Yang W, He L. BRPPFL: A Byzantine-Robust and Privacy-Preserving Framework for Cloud–Edge Federated Learning. Computer Networks. 2026;286:112498.
43. Zhou Z, Chen X, Li E, Zeng L, Luo K, Zhang J. Edge intelligence: paving the last mile of artificial intelligence with edge computing. Proc IEEE. 2019;107(8):1738-62.
44. Deng S, Zhao H, Fang W, Yin J, Dustdar S, Zomaya AY. Edge intelligence: the confluence of edge computing and artificial intelligence. IEEE Internet Things J. 2020;7(8):7457-69.
45. Tramèr F, Zhang F, Juels A, Reiter MK, Ristenpart T. Stealing machine learning models via prediction APIs. In: Proceedings of the 25th USENIX Security Symposium; 2016. p. 601-18.
46. Shokri R, Stronati M, Song C, Shmatikov V. Membership inference attacks against machine learning models. In: Proceedings of the IEEE Symposium on Security and Privacy; 2017. p. 3-18.
47. Papernot N, McDaniel P, Sinha A, Wellman MP. SoK: security and privacy in machine learning. In: Proceedings of the IEEE European Symposium on Security and Privacy; 2018. p. 399-414.
48. Biggio B, Roli F. Wild patterns: ten years after the rise of adversarial machine learning. Pattern Recognit. 2018;84:317-31.
49. Vassilev A, Oprea A, Fordyce A, et al. Adversarial machine learning: a taxonomy and terminology of attacks and mitigations. Gaithersburg, MD, USA: National Institute of Standards and Technology; 2025. NIST AI 100-2e2025.
50. Greshake K, Abdelnabi S, Mishra S, Endres C, Holz T, Fritz M. Not what you've signed up for: compromising real-world LLM-integrated applications with indirect prompt injection. In: Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security; 2023. p. 79-90.
51. Carlini N, Jagielski M, Choquette-Choo CA, et al. Poisoning web-scale training datasets is practical. In: Proceedings of the IEEE Symposium on Security and Privacy; 2024. p. 407-25.
52. Qowi Z, Hudallah N. Combining caesar cipher and hill cipher in the generating encryption key on the vigenere cipher algorithm. J Phys Conf Ser. 2021;1918:042009.
53. Mirkovic J, Martin J, Reiher P. A Taxonomy of DDoS Attacks and DDoS Defense Mechanisms. ACM SIGCOMM Computer Communication Review. 2004;34(2):39-53.
54. Li W, Wang P. Two-factor authentication in industrial internet-of-things: attacks, evaluation and new construction. Future Gener Comput Syst. 2019;101:694-708.
55. Wang D, Cheng H, Wang P, Huang X, Jian G. Zipf's law in passwords. IEEE Trans Inf Forensics Secur. 2017;12(11):2776-91.
56. Ledwaba LPI, Hancke GP, Venter HS, Isaac SJ. Performance Costs of Software Cryptography in Securing New-Generation Internet of Energy Endpoint Devices. IEEE Access. 2018;6:9303-23.
57. Blum M, Vempala S. The complexity of human computation via a concrete model with an application to passwords. Proc Natl Acad Sci USA. 2020;117:9208-15.
58. Ollschlaeger M, Sauter T, Jasperneite J. The future of industrial communication: automation networks in the era of the internet of things and industry 4.0. IEEE Ind Electron Mag. 2017;11:17-27.
59. Mao Y, You C, Zhang J, et al. A survey on mobile edge computing: the communication perspective. IEEE Commun Surv Tutor. 2017;19:2322-58.
60. Qiu T, Chi J, Zhou X, et al. Edge computing in industrial internet of things: architecture, advances and challenges. IEEE Commun Surv Tutor. 2020;22:2462-88.
61. Mach P, Becvar Z. Mobile edge computing: a survey on architecture and computation offloading. IEEE Commun Surv Tutor. 2017;19:1628-56.
62. Gupta A, Tripathi M, Shaikh TJ, et al. A lightweight anonymous user authentication and key establishment scheme for wearable devices. Comput Netw. 2019;149:29-42.
63. Adil M, Almaiah MA, Alsayed AO, et al. An anonymous channel categorization scheme of edge nodes to detect jamming attacks in wireless sensor networks. Sensors. 2020;20:2311.
64. Azrour M, Mabrouki J, Guezzaz A, et al. New enhanced authentication protocol for internet of things. Big Data Min Anal. 2021;4:1-9.
65. Lu YR, Li LX, Peng HP, et al. An energy efficient mutual authentication and key agreement scheme preserving anonymity for wireless sensor networks. Sensors. 2016;16:837.
66. Wu F, Xu L, Kumari S, et al. An efficient authentication and key agreement scheme for multi-gateway wireless sensor networks in IoT deployment. J Netw Comput Appl. 2017;89:72-85.
67. Burrows M, Abadi M, Needham RM. A logic of authentication. Proc R Soc Lond Ser A. 1989;426:233-71.
68. Li X, Niu J, Kumari S, et al. An enhancement of a smart card authentication scheme for multi-server architecture. Wirel Pers Commun. 2015;80:175-92.
69. Mao D, Zhang L, Li X, et al. Trusted authority assisted three-factor authentication and key agreement protocol for the implantable medical system. Wirel Commun Mob Comput. 2018;2018:7579161.
70. Das AK, Sutrala AK, Odelu V, et al. A secure smartcard-based anonymous user authentication scheme for healthcare applications using wireless medical sensor networks. Wirel Pers Commun. 2017;94:1899-933.
71. Liu X, Zhang RS, Liu QD. A temporal credential-based mutual authentication with multiple-password scheme for wireless sensor networks. PLoS One. 2017;12:e0170657.
72. Yu SJ, Park Y. SLUA-WSN: secure and lightweight three-factor-based user authentication protocol for wireless sensor networks. Sensors. 2020;20:4143.